R.M.K
GROUP OF ENGINEERING INSTITUTIONS

R.M.K
GROUP OF
INSTITUTIONS

R.M.K
GROUP OF INSTITUTIONS







R.M.K
GROUP OF
INSTITUTIONS



Please read this disclaimer before proceeding:

This document is confidential and intended solely for the educational purpose of RMK Group of Educational Institutions. If you have received this document through email in error, please notify the system manager. This document contains proprietary information and is intended only to the respective group / learning community as intended. If you are not the addressee you should not disseminate, distribute or copy through e-mail. Please notify the sender immediately by e-mail if you have received this document by mistake and delete this document from your system. If you are not the intended recipient you are notified that disclosing, copying, distributing or taking any action in reliance on the contents of this information is strictly prohibited.

22CS912

CLOUD SECURITY FOUNDATIONS

Department : CSE

Batch/Year : 2023-2027 / IV Year

Prepared /Updated by:

Ms. A. Jasmine Gilda, Associate Professor / RMKEC – CSE

Dr. K. Roslin Dayana, Associate Professor/RMDEC – CSE

Dr. A. Nazreen Banu, Associate Professor/ RMDEC - CSE

Mr. V. M. Jemin, Associate Professor/RMKCET – CSE

Date : 09.05.2026

1. CONTENTS

S. No.	Contents	Page
1	Contents	1
2	Course Objectives	2
3	Pre-Requisites	3
4	Syllabus	4
5	Course outcomes	5
6	CO- PO/PSO Mapping	6
7	Lecture Plan	7
8	Activity based learning	8
9	Lecture Notes	9
10	Assignments	52
11	Part A Questions & Answers	51
12	Part B Questions	55
13	Online Certifications	56
14	Real Time Applications	57
15	Self-Learning / Enrichment Topics	60
16	Assessment Schedule	61
17	Text Books & Reference Books	62
18	Mini Project / Activity	63
19	AI Applications	65

R.M.K GROUP OF INSTITUTIONS

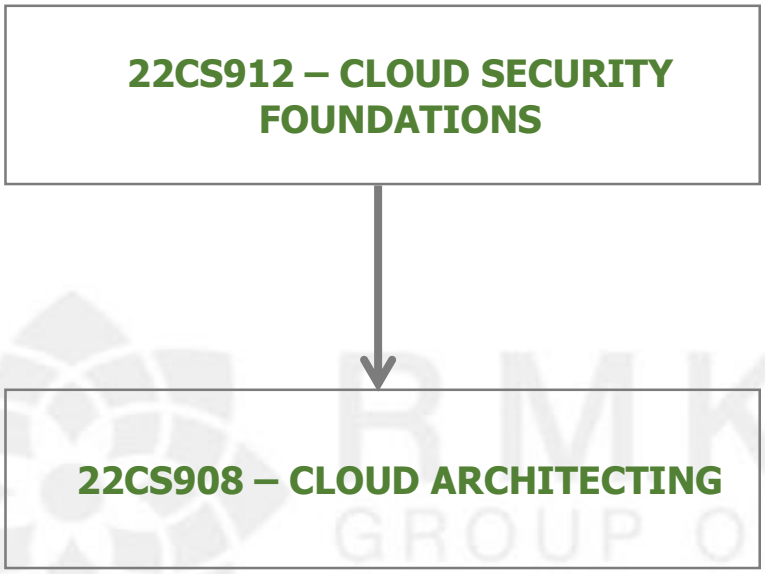
2. COURSE OBJECTIVES

The Course will enable learners to:

- Learn the basics of cloud security, including the shared responsibility model and identity management.
- Set up a secure cloud infrastructure with features like virtual private clouds and security groups.
- Safeguard application data at rest and in transit using encryption and Amazon S3 protection features.
- Learn to capture and analyze log data using AWS services like CloudTrail and CloudWatch.
- Develop skills for identifying and managing security incidents in the cloud, adhering to best practices.

3. PRE REQUISITES

- **Pre-requisite Chart**



4. SYLLABUS

22CS912	CLOUD SECURITY FOUNDATIONS	L	T	P	C
		3	0	0	3

UNIT I SECURITY IN CLOUD **9**

Introduction to Security, Security in the Cloud, Security design principles, Shared responsibility model, Activity: Shared Responsibility Model, Identity and Access Management (IAM) fundamentals, Authenticating and Authorizing with IAM, Examples of authorizing with IAM, Additional authentication and access management services, Using Organizations.

UNIT II SECURING INFRASTRUCTURE **9**

Structure of a three-tier web application, virtual private cloud (VPC), Setting up public and private subnets and internet protocols, Security groups, Network access control lists (ACLs), Load balancers, Protecting compute resources.

UNIT III PROTECTING APPLICATION DATA **9**

Basics on Data Protection, Protect data at rest, Amazon S3 protection features, Protection through encryption, Protect data in transit, protect data in Amazon S3, additional data protection services.

UNIT IV LOGGING AND MONITORING **9**

Importance of logging and monitoring, Capture and collect, Reading a Log File, AWS services with built-in logs, Monitor and report, CloudTrail and Amazon CloudWatch, methods for logging and monitoring, additional AWS services for logging and monitoring, AWS Security Hub.

UNIT V RESPONDING AND MANAGING AN INCIDENT **9**

Identifying an incident, Services that support the discovery and recognition phase, AWS Config and AWS Lambda, Services that support the resolution and recovery phase, Best practices for handling an incident.

TOTAL: 45 PERIODS

R.M.K GROUP OF INSTITUTIONS

5. COURSE OUTCOME

At the end of this course, the students will be able to:

CO1: Learn essential cloud security principles and identity management fundamentals.

CO2: Design and implement secure cloud infrastructure components for effective resource protection.

CO3: Explore methods for securing application data stored in the cloud, including encryption techniques and data protection features.

CO4: Gain proficiency in implementing logging and monitoring practices to detect and respond to security events efficiently in cloud environments.

CO5: Acquire skills to identify and manage security incidents in the cloud, utilizing appropriate tools and techniques for incident detection, analysis, and resolution.

CO6: Proficiently ensure the protection of cloud environments by applying strong security measures across all aspects, ensuring resilience and compliance.

R.M.K GROUP OF INSTITUTIONS

6. CO - PO / PSO MAPPING

CO	HKL	PROGRAM OUTCOMES												PSO		
		PO-1	PO-2	PO-3	PO-4	PO-5	PO-6	PO-7	PO-8	PO-9	PO-10	PO-11	PO-12	PSO-1	PSO-2	PSO-3
CO1	K3	3	2	-	-	2	-	-	1	2	-	-	1	2	2	2
CO2	K3	3	3	3	-	3	-	-	1	-	-	-	2	3	3	2
CO3	K3	3	3	2	-	2	-	-	2	-	-	-	2	3	2	2
CO4	K3	2	3	2	-	2	-	-	1	-	1	-	2	2	2	2
CO5	K3	2	3	2	-	2	-	-	2	1	1	-	3	2	2	2
C06	K3	2	3	2	-	2	-	-	2	2	1	-	3	2	2	2

Correlation Level:

1. Slight (Low)

2. Moderate (Medium)

3. Substantial (High)

If there is no correlation, put "-".

R.M.K GROUP OF INSTITUTIONS

7. LECTURE PLAN

S. No.	Topic	Numberof Periods	CO	Taxonomy Level	Mode of Delivery
1	Structure of a three-tier web application	1	CO2	K2	PPT
2	virtual private cloud (VPC)	1	CO2	K2	PPT
3	Setting up public and private subnets and internet protocols	2	CO2	K3	PPT
4	Security groups	1	CO2	K3	PPT
5	Network access control lists (ACLs)	2	CO2	K3	PPT
6	Load balancers	1	CO2	K2	PPT
7	Protecting compute resources	1	CO2	K3	PPT

8. ACTIVITY BASED LEARNING

Build a Human Cloud Network:

- **Activity:** Students work in groups to physically create a three-tier web application architecture in the classroom. Each student represents an AWS component such as Internet User, Internet Gateway, Load Balancer, Web Server (EC2), Application Server (EC2), Database (RDS), Security Group, Network ACL, and VPC. Using placards and arrows, students demonstrate how a user request travels through the architecture. Other students act as attackers attempting unauthorized access, while the "Security Group" and "Network ACL" students decide whether to allow or deny the traffic.
- **Outcome:** Students will understand the structure of a three-tier architecture, traffic flow, and the role of AWS networking and security components in protecting cloud resources.

Security Rule Simulation Game:

- **Activity:** The classroom is divided into Public Subnet and Private Subnet zones using floor markings or signs. Students carry cards representing different types of network traffic (HTTP, HTTPS, SSH, RDP, Database Request, Malicious Traffic, etc.). Students assigned as Security Groups and Network ACLs receive rule sheets and decide whether each traffic request is Allowed or Denied based on AWS security rules. The instructor changes scenarios (e.g., "Database should not be accessible from the Internet"), and students update their decisions accordingly.
- **Outcome:** Students will gain practical understanding of how Security Groups and Network ACLs control network traffic and protect cloud resources.

R.M.K GROUP OF INSTITUTIONS

9. UNIT II - LECTURE NOTES

1. STRUCTURE OF A THREE-TIER WEB APPLICATION

Introduction:

Modern organizations rely on web applications to provide online services such as internet banking, e-commerce, healthcare, online learning, and government portals. These applications must be scalable, reliable, and secure to support a large number of users while protecting sensitive information. To achieve these objectives, organizations commonly adopt a three-tier web architecture.

A three-tier architecture divides an application into three independent layers: the Presentation Layer, Application Layer, and Data Storage Layer. Each layer performs a specific function and communicates only with the adjacent layer. This separation improves application performance, simplifies maintenance, enhances scalability, and strengthens security by isolating critical resources.

In cloud environments, three-tier architecture is widely used because it supports secure deployment using cloud infrastructure services such as Virtual Private Clouds (VPCs), subnets, and load balancers.

What is a Three-Tier Web Application?

A three-tier web application is a software architecture that separates an application into three logical layers, each with a specific responsibility. Instead of placing all application components on a single server, the user interface, business logic, and database are deployed separately. This modular approach allows each layer to be developed, managed, and scaled independently.

- Presentation Layer – Provides the user interface
- Application Layer/Business Layer – Processes business logic
- Data Storage Layer – Stores application data

By separating these layers, organizations can improve application performance, simplify maintenance, and implement security controls based on the sensitivity of each layer.

R.M.K GROUP OF INSTITUTIONS

Components of Three-Tier Architecture:

A three-tier architecture consists of three interconnected layers, each responsible for a specific function within the application.

Presentation Layer:

The presentation layer is the front-end of the application that users interact with through a web browser or mobile application. It receives user requests and displays responses.

Common technologies include HTML, CSS, JavaScript, and React. AWS services include Amazon EC2, Amazon S3, CloudFront, and Application Load Balancer.

Since this layer is directly accessible from the Internet, it is often the first target of cyberattacks and requires secure communication and proper user authentication.

Security considerations:

- Enable HTTPS using SSL/TLS.
- Protect applications with AWS WAF and AWS Shield.
- Validate user input to prevent Cross-Site Scripting (XSS) and Cross-Site Request Forgery (CSRF).
- Use Multi-Factor Authentication (MFA) for user accounts.

Application Layer:

The application layer contains the business logic. It validates requests, authenticates users, processes transactions, and communicates with the database.

Common AWS services include Amazon EC2, AWS Lambda, Amazon ECS, and Amazon EKS.

Typical functions performed by this layer include:

- User authentication
- Order processing
- Payment validation
- Report generation
- Business rule implementation

Because this layer processes critical operations, it must ensure that requests are handled correctly and only authorized users can access application resources.

Security considerations:

R.M.K GROUP OF INSTITUTIONS

- Apply the Principle of Least Privilege.
- Use IAM roles instead of hard-coded credentials.
- Validate all user inputs.
- Protect APIs using authentication and authorization.
- Store secrets securely using AWS Secrets Manager.

Data Storage Layer:

The data layer stores organizational data such as customer records, financial transactions, and application information. AWS services include Amazon RDS, Amazon Aurora, and Amazon DynamoDB.

Since this layer stores sensitive information, it is usually placed in a private network where it is accessible only through the application layer. This helps prevent direct access from external users and improves overall security.

Security considerations:

- Store databases in private subnets.
- Enable encryption at rest and in transit.
- Perform automated backups.
- Restrict database access to application servers only.
- Enable monitoring and auditing.

Request Flow in a Three-Tier Web Application:

A user request passes through each layer of the application before a response is returned.

Step 1: A user accesses the application using a web browser or mobile device.

Step 2: The request reaches the Presentation Layer, which collects the user's input and forwards it to the Application Layer.

Step 3: The Application Layer validates the request, applies business logic, and determines whether database access is required.

Step 4: If data is needed, the Application Layer communicates with the Data Storage Layer

R.M.K GROUP OF INSTITUTIONS

to retrieve or update information.

Step 5: The database returns the requested information to the Application Layer.

Step 6: The Application Layer processes the data and sends the response back to the Presentation Layer.

Step 7: The Presentation Layer displays the final output to the user.

This layered communication ensures that users never communicate directly with the database, reducing security risks and improving system organization.

Why Three-Tier Architecture is Preferred in Cloud Computing:

Cloud applications are expected to support thousands of users while maintaining high availability and strong security. Three-tier architecture is preferred because it separates application components into independent layers, allowing each layer to be managed and scaled separately.

From a security perspective, only the Presentation Layer is exposed to the Internet, while the Application Layer and Data Storage Layer remain protected within internal networks. This reduces the attack surface and prevents unauthorized users from directly accessing sensitive business logic or databases.

Cloud platforms also allow each layer to be deployed on separate virtual machines or containers, making it easier to update, monitor, and maintain applications without affecting other layers.

Security Benefits:

A three-tier architecture improves security by:

- Reducing the attack surface.
- Isolating sensitive resources.
- Supporting defense in depth.
- Enforcing network segmentation.
- Improving availability with load balancing and multiple Availability Zones.
- Simplifying compliance with security standards.

Common Security Threats:

Although three-tier architecture improves security, each layer is exposed to different types of

R.M.K GROUP OF INSTITUTIONS

cyber threats.

Presentation Layer

Since the Presentation Layer is publicly accessible, it is commonly targeted by attacks such as:

- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Session Hijacking
- Clickjacking
- Phishing attacks
- Distributed Denial-of-Service (DDoS) attacks

These attacks primarily target users and attempt to compromise application availability or steal sensitive information.

Application Layer

The Application Layer processes user requests and business logic, making it vulnerable to application-level attacks such as:

- SQL Injection
- Command Injection
- API Abuse
- Authentication Bypass
- Broken Access Control
- Remote Code Execution (RCE)

These threats exploit vulnerabilities in application code and business processes to gain unauthorized access or manipulate application behavior.

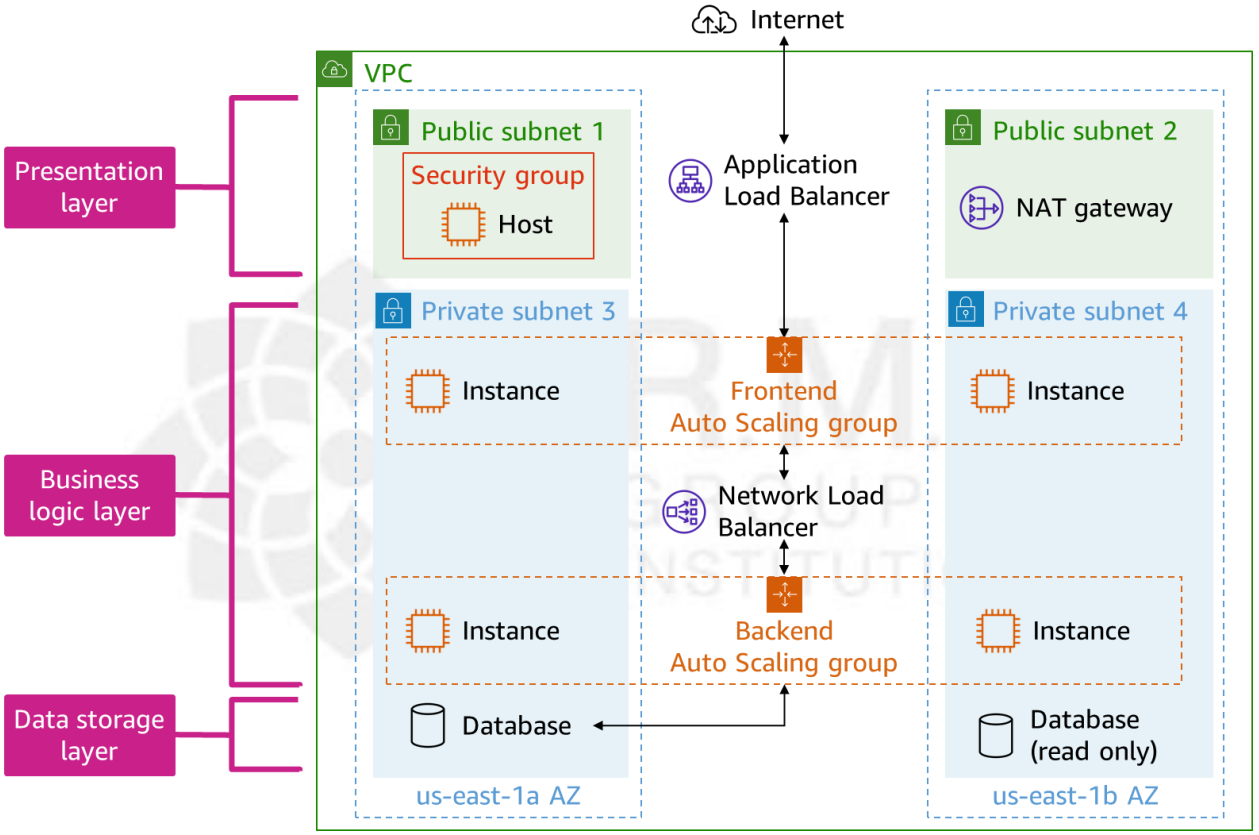
Data Storage Layer

The Data Storage Layer stores sensitive organizational data and is therefore a high-value target for attackers.

Common threats include:

- Unauthorized database access
- Data theft
- Insider threats
- Database misconfiguration
- Ransomware attacks
- Exposure of backup data

Compromising this layer can lead to data breaches, financial losses, and reputational damage.



The diagram illustrates a three-tier web application deployed in an AWS Virtual Private Cloud (VPC) across two Availability Zones (AZs) to provide high availability and fault tolerance.

- The Presentation Layer is deployed in public subnets. It contains the web or frontend servers that receive requests from users over the Internet. An Application Load Balancer (ALB) distributes incoming traffic across multiple frontend instances managed by an Auto Scaling Group, ensuring efficient load distribution and continuous availability.

- The Application (Business Logic) Layer is deployed in private subnets. It processes user requests, applies business logic, and communicates with the database. A Network Load Balancer (NLB) distributes traffic to backend application servers, while an Auto Scaling Group automatically adds or removes backend instances based on application demand.
- The Data Storage Layer contains the application's database. A primary database is hosted in one Availability Zone, and a read replica or standby database is maintained in the second Availability Zone to improve availability and support disaster recovery. The database is accessible only by the application layer, preventing direct access from users.

2. VIRTUAL PRIVATE CLOUD (VPC)

2.1 Amazon Virtual Private Cloud (Amazon VPC)

As organizations increasingly migrate their applications and data to the cloud, securing the network infrastructure becomes a critical requirement. Unlike traditional on-premises data centers, cloud resources are hosted in a shared environment. Therefore, organizations need a secure and isolated network where they can deploy their applications without interference from other cloud users. Amazon Virtual Private Cloud (Amazon VPC) provides this capability.

Amazon Virtual Private Cloud (Amazon VPC) is a service offered by AWS that enables users to create a logically isolated virtual network within the AWS Cloud. A VPC allows organizations to launch AWS resources, such as Amazon EC2 instances, databases, and application servers, in a secure and customizable network environment. Although the underlying physical infrastructure is shared among multiple AWS customers, each VPC is isolated, ensuring that resources in one VPC cannot directly communicate with resources in another VPC unless explicitly configured.

A VPC gives organizations complete control over their virtual networking environment. Users can define their own IP address range, create multiple subnets, configure route tables, attach network gateways, and implement various security controls according to their application requirements.

Some of the key features of Amazon VPC include:

- Logical Isolation: Each VPC is isolated from other VPCs in the AWS Cloud, providing a

R.M.K GROUP OF INSTITUTIONS

secure environment for deploying cloud resources.

- Custom IP Address Range: Organizations can define their own IPv4 or IPv6 address ranges using Classless Inter-Domain Routing (CIDR) notation.
- Subnet Creation: A VPC can be divided into multiple subnets to separate different application components based on functionality and security requirements.
- Custom Routing: Route tables allow administrators to control how network traffic flows within the VPC and between external networks.
- Network Connectivity: Internet Gateways, NAT Gateways, VPN connections, and Direct Connect can be used to enable secure communication between the VPC, the Internet, and on-premises networks.
- Layered Security: Multiple security mechanisms, such as Security Groups and Network Access Control Lists (Network ACLs), help control inbound and outbound traffic.

From a cloud security perspective, Amazon VPC forms the foundation of network security in AWS. It enables organizations to isolate sensitive resources, control network traffic, and implement the principle of defense in depth by combining multiple security mechanisms. For example, web servers can be placed in public subnets to receive Internet traffic, while application servers and databases remain protected in private subnets.

2.2 VPCs and Subnets

A Virtual Private Cloud (VPC) provides a secure virtual network, but deploying all resources within a single network can increase security risks and make traffic management difficult. To improve security and organize resources efficiently, a VPC is divided into smaller logical networks called **subnets**.

Virtual Private Cloud (VPC):

A VPC is a virtual network dedicated to an AWS account. It belongs to a single AWS Region but can extend across multiple Availability Zones within that Region. All AWS resources deployed inside the VPC communicate using private IP addresses unless public access is

specifically configured.

The main characteristics of a VPC are:

- It is logically isolated from other VPCs in the AWS Cloud.
- It belongs to a single AWS Region.
- It can span multiple Availability Zones.
- It provides complete control over IP addressing, routing, and network security.
- It acts as the primary security boundary for cloud resources.

Because a VPC isolates resources from other customers, it helps organizations maintain confidentiality and reduce the risk of unauthorized access.

Subnets:

A **subnet** is a smaller network created by dividing the IP address range of a VPC. Each subnet occupies a specific Availability Zone and contains a range of IP addresses assigned to AWS resources.

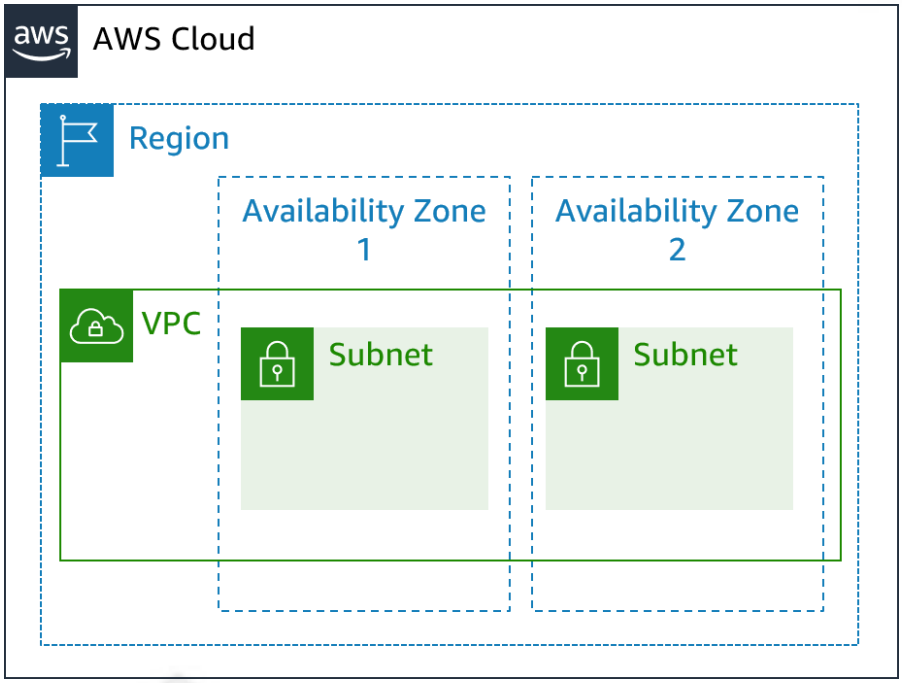
Subnets allow organizations to group resources according to their roles and security requirements. Instead of placing all servers in a single network, different components of an application can be deployed in separate subnets.

Each subnet belongs to only one Availability Zone. However, multiple subnets can be created across different Availability Zones to improve fault tolerance and high availability.

The main characteristics of a subnet are:

- It is a subdivision of a VPC.
- It belongs to **only one Availability Zone**.
- It contains a unique range of IP addresses.
- It is classified as either a **Public Subnet** or a **Private Subnet**.
- Resources within the same VPC can communicate using private IP addresses, subject to routing and security rules.

R.M.K GROUP OF INSTITUTIONS



Above figure illustrates a VPC spanning two Availability Zones, with one subnet located in each Availability Zone. This design improves application availability and ensures that resources continue to operate even if one Availability Zone becomes unavailable.

Types of Subnets:

Subnets are generally classified into two categories based on their accessibility.

Public Subnet

A Public Subnet is a subnet whose route table contains a route to an Internet Gateway (IGW). Resources deployed in a public subnet can communicate with the Internet if they are assigned a public IP address.

Public subnets are typically used for:

- Web servers
- Load Balancers
- Bastion Hosts
- Internet-facing applications

Since these resources are exposed to external users, they require stronger security controls such as firewalls, monitoring, and secure access policies.

Private Subnet

A Private Subnet is a subnet that does not allow direct communication with the Internet. Resources in a private subnet use only private IP addresses and are accessible only from within the VPC or through controlled network connections.

Private subnets are commonly used for:

- Application servers
- Database servers
- Internal APIs
- Backend services

Placing sensitive resources in private subnets reduces the attack surface because attackers cannot directly access these systems from the Internet.

Role of VPCs and Subnets in Cloud Security:

From a cloud security perspective, VPCs and subnets provide network isolation and traffic segmentation, which are fundamental principles of secure cloud architecture.

By separating Internet-facing resources from internal resources, organizations can:

- Limit direct exposure of sensitive systems.
- Reduce the attack surface.
- Control communication between different application components.
- Apply different security policies to different network segments.
- Improve compliance with organizational and regulatory security requirements.

For example, in a three-tier web application, web servers are typically deployed in **public subnets**, while application servers and databases are deployed in **private subnets**. This ensures that only the Presentation Layer is accessible from the Internet, while the Business Layer and Data Storage Layer remain protected within the VPC.

Distributing subnets across multiple Availability Zones also improves high availability and fault tolerance, ensuring that applications continue to operate even if one Availability Zone experiences a failure.

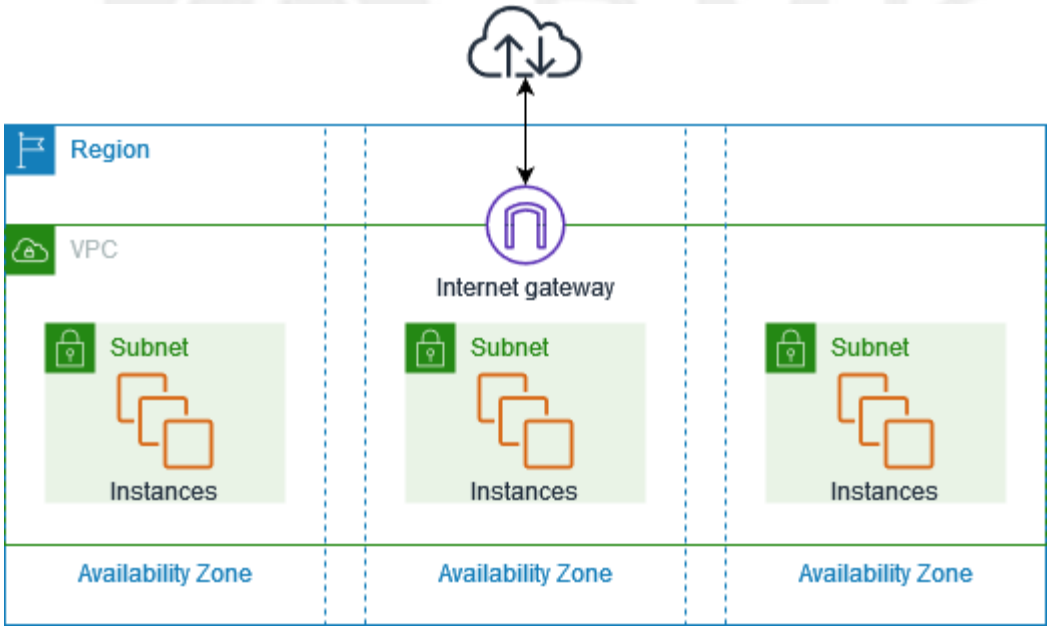
R.M.K GROUP OF INSTITUTIONS

3. SETTING UP PUBLIC AND PRIVATE SUBNETS AND INTERNET PROTOCOLS

3.1 Internet gateway

An **Internet Gateway (IGW)** is a VPC component that enables communication between resources in a VPC and the internet. It allows instances with public IP addresses to send and receive internet traffic. Internet Gateway supports both **IPv4** and **IPv6** traffic and provides high availability without requiring additional configuration or management. AWS does not charge separately for attaching an Internet Gateway to a VPC.

To provide internet access, the Internet Gateway must first be created and attached to the VPC. The subnet's route table should then contain a route that directs internet traffic to the Internet Gateway. The EC2 instance must have a **public IPv4 address**, **Elastic IP address**, or **IPv6 address**. Finally, the **Security Groups** and **Network ACLs** should allow the required inbound and outbound traffic. Only after these configurations can the instance communicate with the internet.



3.2 NAT Gateway

A **Network Address Translation (NAT) Gateway** is an AWS-managed service that enables instances in a private subnet to access the internet or other AWS services while preventing external systems from initiating connections to those instances. This ensures that private resources remain protected from direct internet exposure.

R.M.K GROUP OF INSTITUTIONS

A NAT Gateway is always deployed in a public subnet and is associated with an Elastic IP address. When an instance in a private subnet sends an internet request (for example, downloading software updates or security patches), the traffic is forwarded to the NAT Gateway. The NAT Gateway translates the private IP address into its Elastic IP address, sends the request to the internet, and returns the response to the instance. Since the communication is initiated only from inside the VPC, external users cannot directly access the private instances.

To use a NAT Gateway, the following steps are required:

- Create the NAT Gateway in a public subnet.
- Associate an Elastic IP address with it.
- Update the route table of the private subnet so that internet-bound traffic is directed to the NAT Gateway.
- Ensure the public subnet has a route to the Internet Gateway.

AWS also provides a NAT Instance, but AWS recommends using a NAT Gateway because it is fully managed, highly available, scalable, and requires less administration.

Security Perspective

- Protects private resources from direct internet access.
- Allows secure downloading of updates and patches.
- Reduces the attack surface of the VPC.

3.3 Private Subnet

A **Private Subnet** is a subnet whose resources are not directly accessible from the internet. Instances deployed in a private subnet are assigned only **private IP addresses**, making them invisible to external users. This design provides an additional layer of protection for sensitive applications and data.

Private subnets are commonly used to host:

- Database servers
- Application servers
- Internal APIs
- Backend services

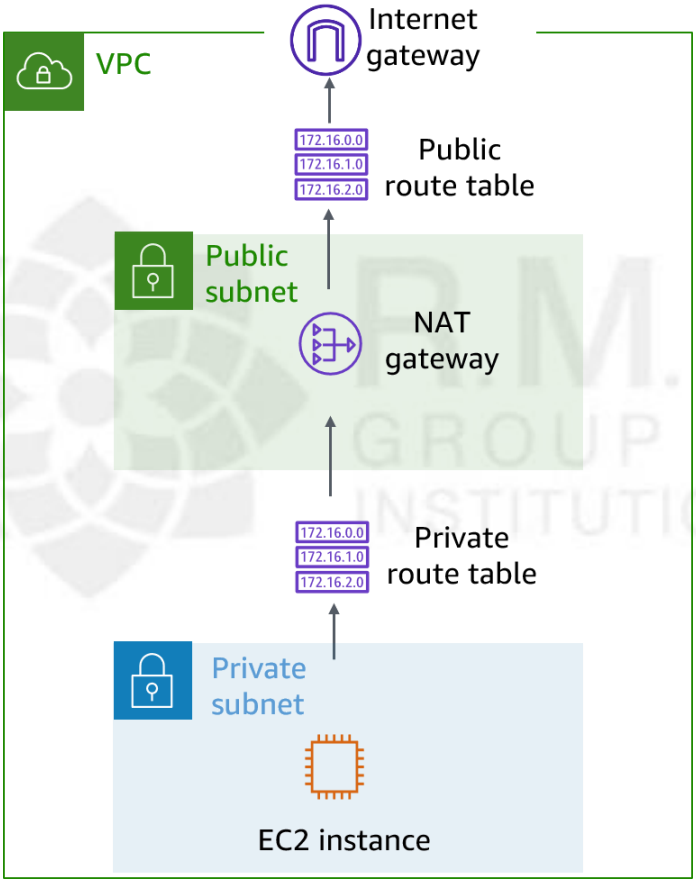
Although inbound internet traffic is blocked, instances in a private subnet can still access the

internet through a NAT Gateway for tasks such as installing software updates, downloading packages, or connecting to AWS services.

Each private subnet has its own IP address range defined by a CIDR block. The IP addresses assigned to one subnet should never overlap with another subnet within the same VPC.

Security Benefits

- Prevents direct attacks from the internet.
- Protects sensitive workloads such as databases.
- Supports the principle of least exposure by limiting network accessibility.



3.4 Public Subnet

A Public Subnet is a subnet whose resources can communicate directly with the internet. This is achieved by associating the subnet's route table with an Internet Gateway and assigning a public IP address to the instances.

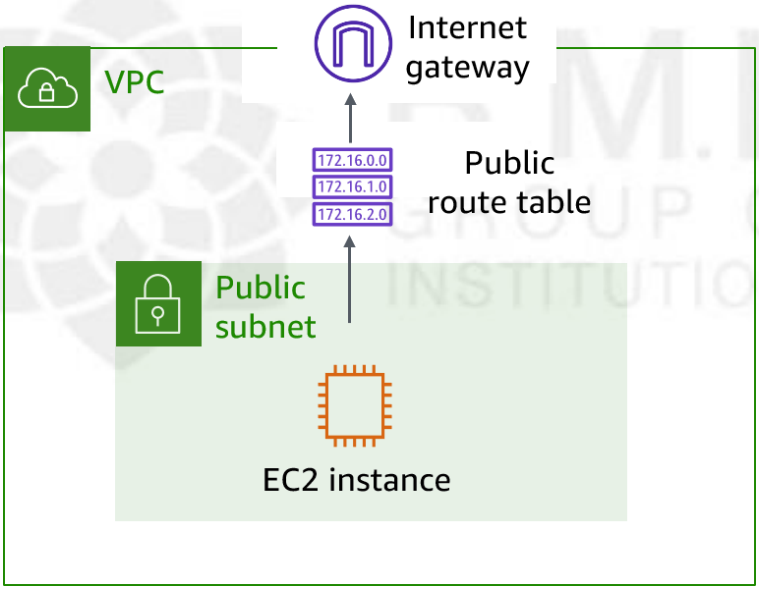
Resources commonly placed in a public subnet include:

- Web servers
- Load Balancers
- Bastion Hosts
- Public-facing APIs

For an EC2 instance to become publicly accessible, the following conditions must be satisfied:

- The instance must have a public IP address or an Elastic IP address.
- The subnet's route table must contain a route to the Internet Gateway.
- Security Groups and Network ACLs must allow the required inbound and outbound traffic.

From a security standpoint, only components that require direct internet communication should be deployed in a public subnet. AWS recommends placing Load Balancers in public subnets while keeping application servers in private subnets to minimize security risks.



3.5 IP Addressing

Every device connected to a network requires a unique IP address for communication. In AWS, when a Virtual Private Cloud (VPC) is created, a CIDR (Classless Inter-Domain Routing) block is assigned to define the range of private IP addresses available within that VPC.

The CIDR block determines the number of IP addresses that can be allocated. AWS supports CIDR block sizes ranging from /16 (largest) to /28 (smallest).

For example:

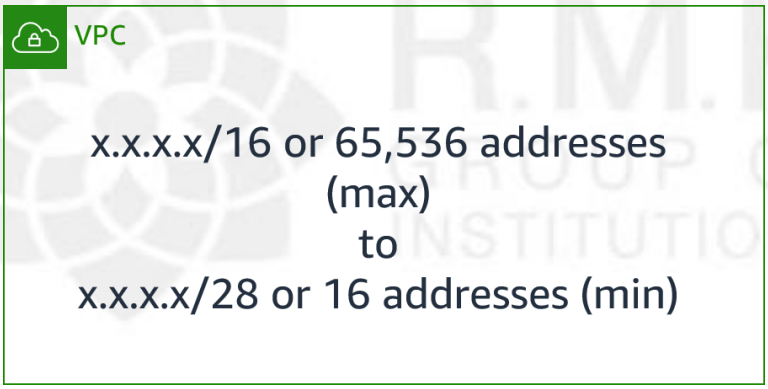
- 10.0.0.0/16 provides 65,536 IP addresses.
- 10.0.1.0/24 provides 256 IP addresses.

A subnet receives a portion of the VPC's CIDR block. Multiple subnets can be created within a VPC, but their CIDR ranges must never overlap. Although the original CIDR block of a VPC cannot be modified, additional CIDR blocks can be added if more IP addresses are required.

Proper IP address planning improves scalability, simplifies network management, and reduces routing conflicts.

Security Importance

- Ensures unique communication between resources.
- Prevents IP conflicts.
- Supports secure network segmentation.



3.6 Reserved IP Addresses

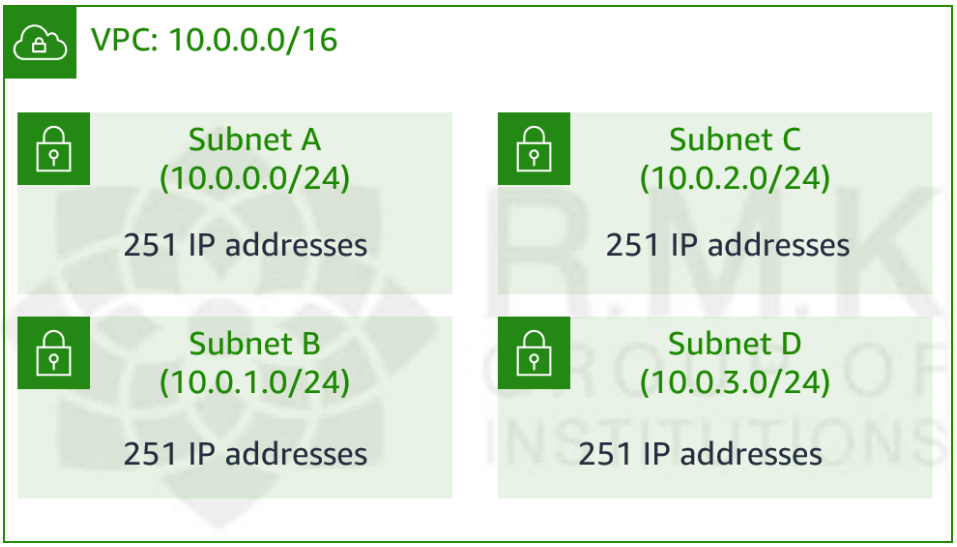
Whenever a subnet is created, AWS automatically reserves **five IP addresses** from its CIDR block for internal networking purposes. These addresses cannot be assigned to EC2 instances or other resources.

The reserved addresses are:

IP Addresses for CIDR Block 10.0.0.0/24	Reserved for
10.0.0.0	Network address

10.0.0.1	Internal communication
10.0.0.2	Domain Name System (DNS) resolution
10.0.0.3	Future use
10.0.0.255	Network broadcast address

For example, a subnet with the CIDR block **10.0.0.0/24** contains **256 IP addresses**. Since AWS reserves five addresses, only **251 IP addresses** are available for resource allocation. Understanding reserved addresses is important while designing subnet sizes and estimating resource capacity.



3.7 Public IP Address

A **Public IP Address** allows an AWS resource to communicate directly with the internet. When an EC2 instance is launched in a public subnet, AWS can automatically assign a public IP address if the subnet is configured to do so.

A public IP address enables:

- Internet access to the instance.
- Remote administration using SSH or RDP.
- Hosting public web applications and APIs.

However, AWS automatically releases the public IP address when an instance is stopped and assigns a new one when it is restarted. Therefore, public IP addresses are considered dynamic.

For long-term production workloads where a permanent IP address is required, AWS recommends using an Elastic IP Address.

Security Consideration

Only instances that require direct internet communication should receive public IP addresses. Sensitive workloads should remain in private subnets.

3.8 Elastic IP Address

An **Elastic IP Address (EIP)** is a static public IPv4 address allocated to an AWS account. Unlike a standard public IP address, an Elastic IP remains the same until it is explicitly released by the user.

Elastic IP addresses are useful for production environments because applications, users, and DNS records can always refer to the same IP address. If an EC2 instance fails, the Elastic IP can quickly be reassigned to another instance, reducing downtime and improving service availability.

Key characteristics include:

- Static public IPv4 address.
- Can be associated with any EC2 instance or network interface.
- Useful for disaster recovery and failover.
- Unused Elastic IP addresses may incur additional charges.

Security Importance

- Supports business continuity during failures.
- Simplifies DNS management.
- Provides stable connectivity for production services.

3.9 Elastic Network Interface (ENI)

An **Elastic Network Interface (ENI)** is a virtual network adapter that connects an EC2 instance to a VPC. Every EC2 instance is automatically assigned one primary network interface, and additional interfaces can be attached depending on the instance type.

Each ENI stores important networking information such as:

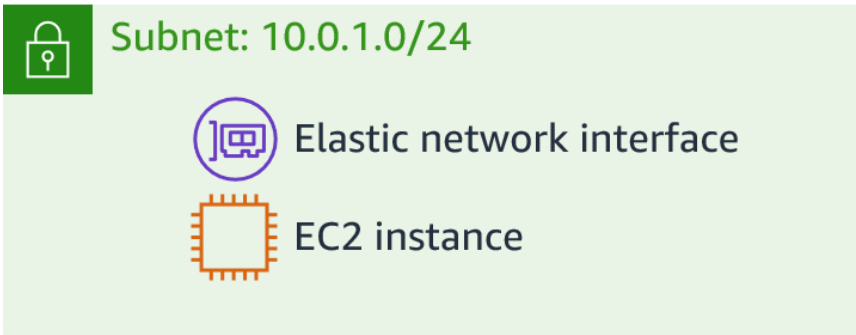
- Private IP addresses
- Elastic IP addresses
- MAC address

R.M.K GROUP OF INSTITUTIONS

- Security Groups

One of the major advantages of an ENI is that it can be detached from one EC2 instance and attached to another without losing its network configuration. This capability is useful during maintenance, disaster recovery, and failover operations.

In digital forensics, investigators may attach an ENI to another instance to analyze network activity without affecting the original workload.



3.10 Route Tables and Routes

A **Route Table** is a collection of routing rules that determines how network traffic travels between subnets, AWS services, and external networks. Every subnet in a VPC must be associated with a route table.

Each route contains two components:

- **Destination** – The network address where the traffic is intended to go.
- **Target** – The resource through which the traffic is forwarded, such as an Internet Gateway, NAT Gateway, or Virtual Private Gateway.

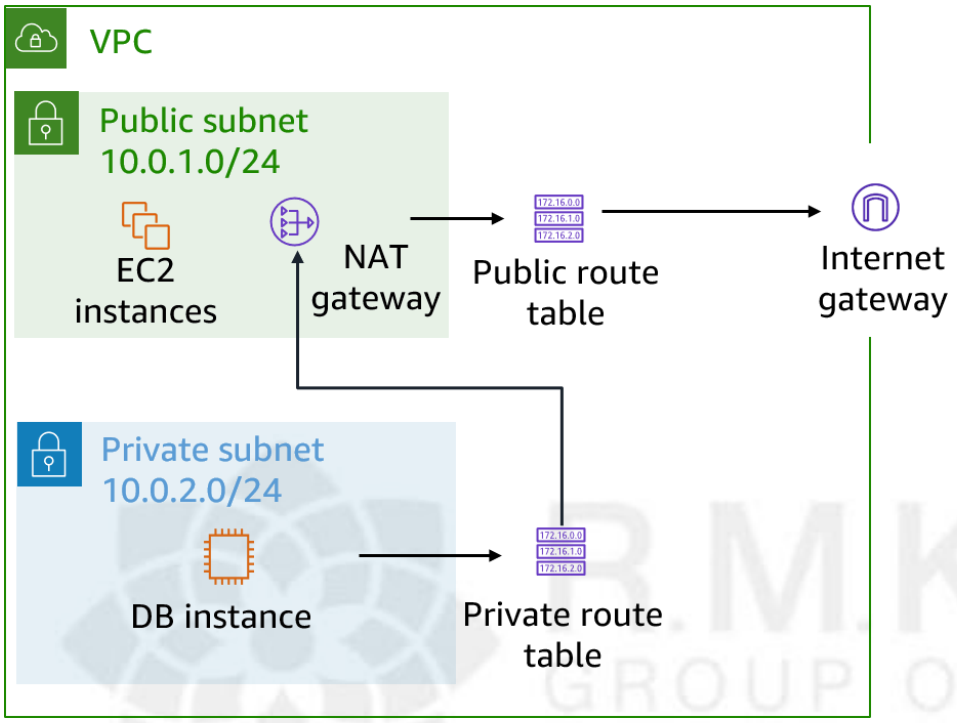
Every route table automatically includes a local route, which allows communication between resources inside the same VPC. This local route cannot be removed.

AWS creates a Main Route Table when a VPC is created. If a subnet is not associated with a custom route table, it automatically uses the main route table. Multiple subnets can share a route table, but a subnet can be associated with only one route table at a time.

Proper route table configuration ensures that only authorized traffic reaches network resources, making routing an important aspect of cloud security.

Security Benefits

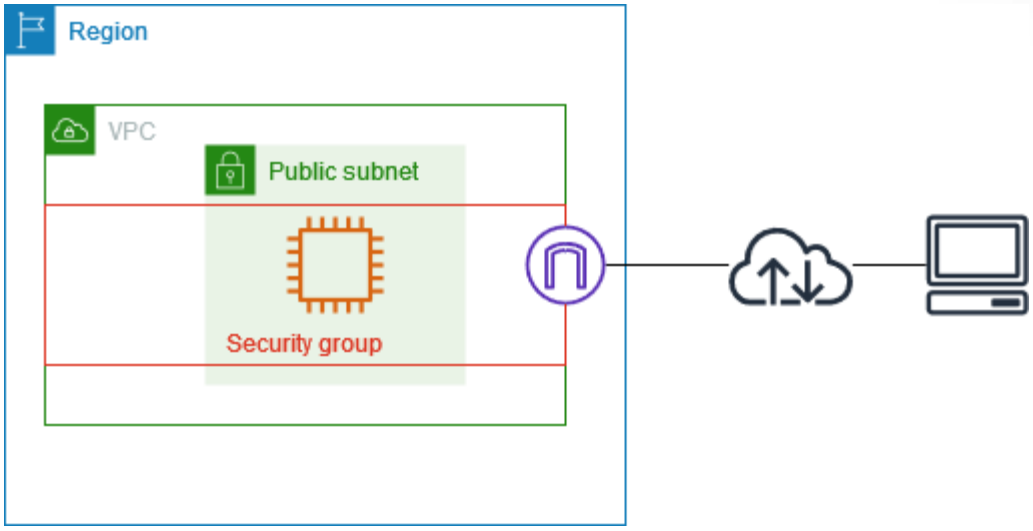
- Controls network traffic flow.
- Isolates public and private resources.
- Prevents unauthorized network access.
- Supports secure VPC architecture.

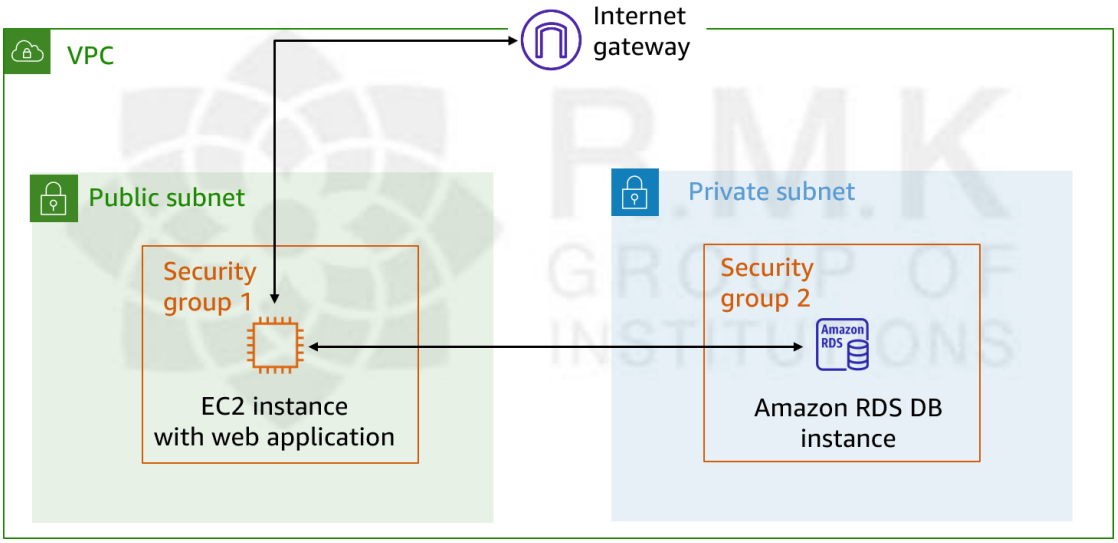


4. SECURITY GROUPS

A **Security Group** is a virtual firewall that controls the network traffic allowed to reach or leave an AWS resource, such as an Amazon EC2 instance. It protects resources by allowing only authorized traffic while blocking unauthorized access. Security Groups operate at the **instance level**, meaning each EC2 instance can have its own set of security rules even if multiple instances are located in the same subnet.

When a security group is associated with an EC2 instance, every incoming and outgoing network request is checked against the rules defined in the security group. Only traffic that matches these rules is allowed to pass. Since security groups are attached directly to instances, they provide fine-grained access control and help implement the **principle of least privilege**, allowing only the minimum required network access.





The public subnet contains an EC2 instance that is protected by security group 1. The private subnet contains an Amazon Relational Database Service (Amazon RDS) database instance that is protected by security group 2. Communication is allowed between the two security groups, and the internet can communicate with security group 1.

4.1 Features of Security Groups

Security Groups provide flexible and secure access control for AWS resources. They are easy to configure and automatically protect instances by filtering network traffic.

Some important features of Security Groups are:

- Act as virtual firewalls for EC2 instances and other supported AWS resources.
- Operate at the instance level, not at the subnet level.
- Control both inbound (incoming) and outbound (outgoing) traffic.
- Multiple security groups can be attached to a single resource.
- A security group can be associated with resources within the same VPC or, using Security Group VPC Association, with resources in other VPCs in the same AWS Region.
- Each security group contains a collection of rules that specify the source or destination, protocol, and port number for the allowed traffic.

4.2 Security Group Rules

Security group rules determine which network traffic is permitted to enter or leave an AWS resource. Every rule consists of the following components:

- **Protocol** – Specifies the communication protocol such as TCP, UDP, or ICMP.
- **Port Range** – Defines the network port or range of ports to allow.
- **Source (Inbound Rule)** – Specifies the IP address, CIDR block, or another security group from which traffic is allowed.
- **Destination (Outbound Rule)** – Specifies where outgoing traffic is permitted.
- Unlike traditional firewalls, security groups contain only **allow rules**. They do not support explicit deny rules. Any traffic that is not explicitly allowed is automatically denied.

4.3 Inbound and Outbound Rules

A security group controls two types of network traffic:

Inbound Rules

Inbound rules control the traffic entering an AWS resource. When a security group is created, it does not contain any inbound rules. As a result, all incoming traffic is denied until appropriate rules are added.

For example:

- Allow SSH (Port 22) only from the administrator's IP address.
- Allow HTTP (Port 80) and HTTPS (Port 443) from the internet for web applications.

R.M.K GROUP OF INSTITUTIONS

Outbound Rules

Outbound rules control the traffic leaving an AWS resource. By default, AWS allows all outbound traffic. Administrators can modify these rules to permit communication only with approved destinations.

Restricting outbound traffic improves security by preventing unauthorized communication with external systems.

4.4 Stateful Nature of Security Groups

Security Groups are **stateful**, meaning they automatically track established network connections. If an EC2 instance sends a request to another system, the response is automatically allowed to return, even if there is no inbound rule permitting that response. Similarly, if inbound traffic is allowed, the response generated by the instance is automatically permitted without requiring an outbound rule.

This stateful behavior simplifies firewall configuration and reduces the number of rules that administrators need to manage.

Example

- A user connects to an EC2 instance using SSH.
- The inbound SSH rule allows the connection.
- The response traffic is automatically permitted because the security group is stateful.

4.5 Default Security Group

Every Virtual Private Cloud (VPC) is created with a **default security group**. Resources that are not assigned another security group automatically use this default group.

The default security group has the following characteristics:

- Denies all inbound traffic from external sources.
- Allows inbound communication from other resources associated with the same security group.
- Allows all outbound traffic by default.

Although the default security group is suitable for basic communication, production environments should use custom security groups with carefully defined rules.

R.M.K GROUP OF INSTITUTIONS

4.6 Security Group Configuration

When creating a security group, AWS requires the following information:

- A unique security group name within the VPC.
- A meaningful description of its purpose.
- Inbound rules based on application requirements.
- Outbound rules if communication needs to be restricted.
- A security group name:
- Must be unique within the VPC.
- Is not case-sensitive.
- Cannot begin with **sg-**.
- Can include letters, numbers, spaces, and selected special characters.
- Providing meaningful names and descriptions makes security management easier, especially in large cloud environments.

4.7 Traffic Not Filtered by Security Groups

Security Groups do not inspect or filter certain AWS-managed network traffic. These include:

- Amazon DNS services
- Amazon DHCP service
- EC2 instance metadata service
- Amazon ECS task metadata endpoints
- Windows license activation traffic
- Amazon Time Sync Service
- Reserved IP addresses used by the default VPC router

These services are managed internally by AWS to ensure the proper operation of cloud resources.

4.8 Best Practices for Using Security Groups

The following best practices improve the security of AWS resources:

- Follow the principle of least privilege by allowing only the required network access.

R.M.K GROUP OF INSTITUTIONS

- Create separate security groups for resources with different security requirements.
- Allow SSH (Port 22) or RDP (Port 3389) access only from trusted IP addresses instead of allowing access from anywhere (0.0.0.0/0).
- Open only the ports required by the application.
- Periodically review and remove unused or unnecessary security group rules.
- Use Security Groups together with Network Access Control Lists (NACLs) to provide multiple layers of network security.
- Restrict permissions so that only authorized IAM users or roles can create or modify security groups.

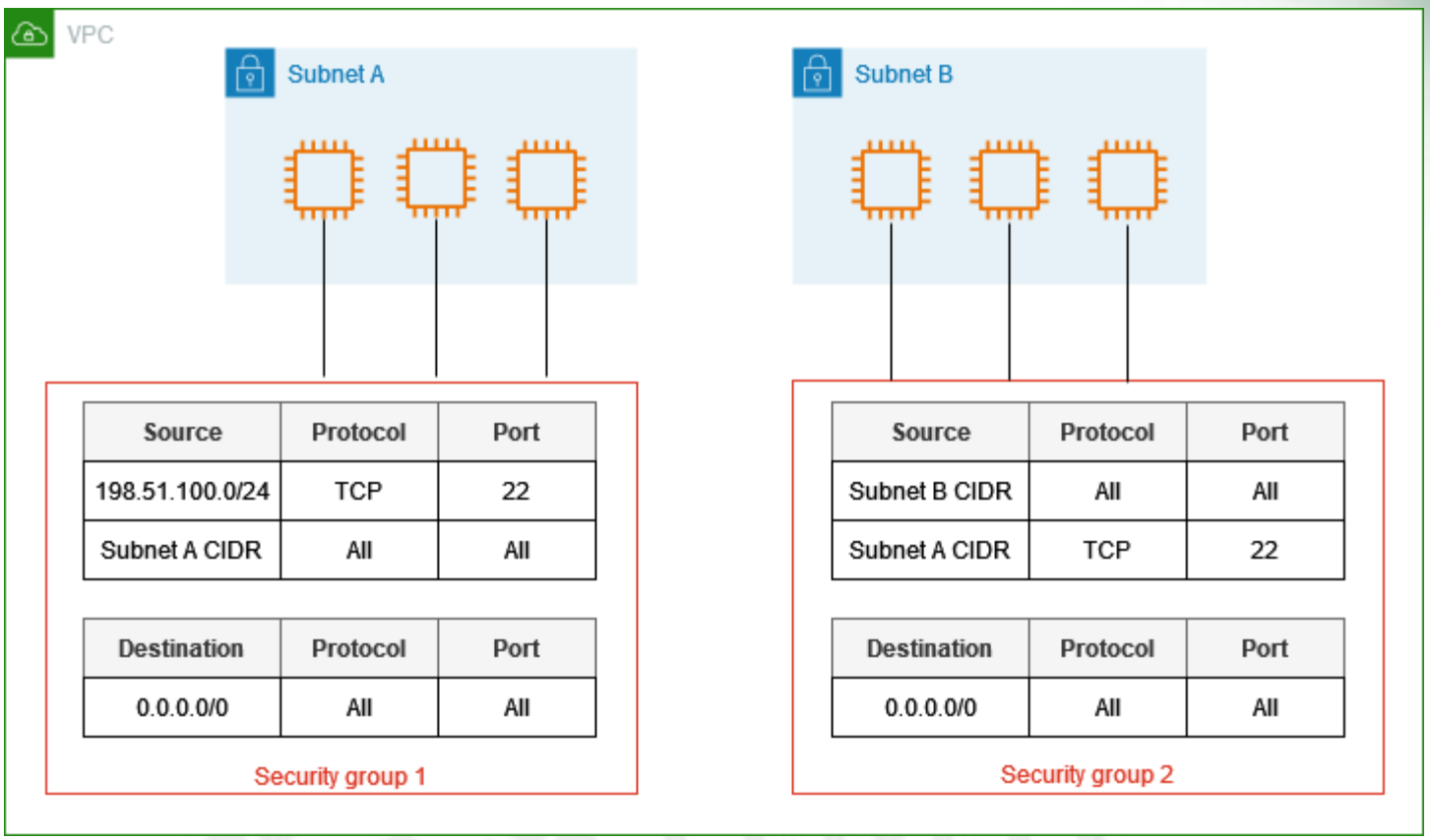
4.9 Example of Security Groups

Consider a VPC containing two subnets:

- **Subnet A** hosts web servers and is associated with **Security Group 1**.
- **Subnet B** hosts database servers and is associated with **Security Group 2**.
- The security group rules can be configured as follows:
- Security Group 1 allows:
    - SSH access from the administrator's network.
    - Communication between web servers in the same security group.
- Security Group 2 allows:
    - Communication between database servers.
    - SSH access only from the web servers in Security Group 1.
- Both security groups use the default outbound rule, allowing resources to initiate outbound communication.

This architecture ensures that database servers remain inaccessible from the internet while still allowing secure communication with application servers.

R.M.K GROUP OF INSTITUTIONS



Security Perspective

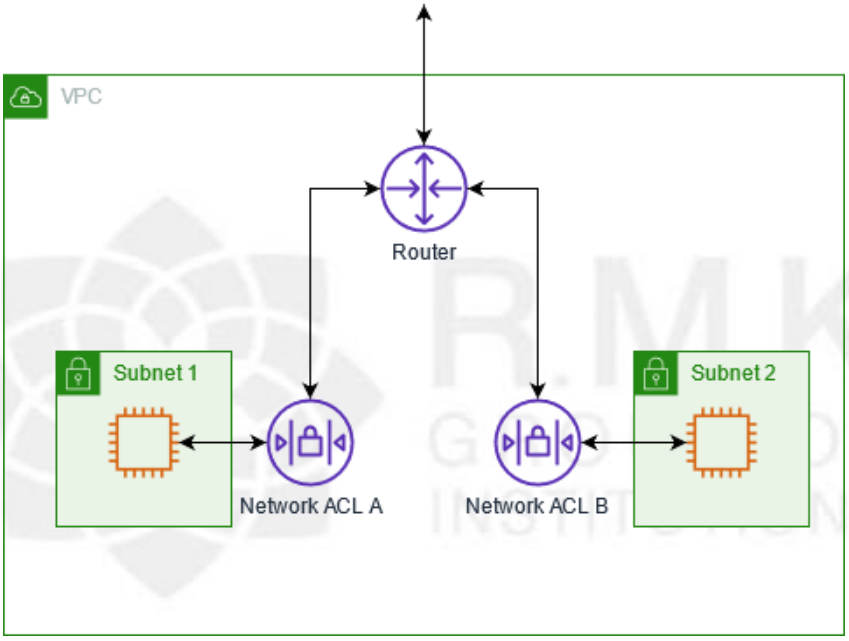
Security Groups are one of the most important security mechanisms in AWS. They provide **instance-level protection** by controlling which traffic is allowed to enter or leave cloud resources. Properly configured security groups reduce the attack surface, prevent unauthorized access, and help organizations implement secure network architectures following cloud security best practices.

5. NETWORK ACCESS CONTROL LISTS (ACLS)

A Network Access Control List (Network ACL or NACL) is a security feature in Amazon VPC that controls inbound (incoming) and outbound (outgoing) traffic at the subnet level. It acts as a firewall for an entire subnet, allowing or denying network traffic based on the rules you configure. Unlike Security Groups, which protect individual EC2 instances, a Network ACL protects all resources within a subnet.

Every VPC comes with a default Network ACL that allows all inbound and outbound traffic. You can also create custom Network ACLs to define your own allow and deny rules. This provides an additional layer of security for your VPC and helps control network access more effectively.

When traffic enters a VPC from the internet, a VPN connection, or a VPC peering connection, it is directed to the appropriate subnet. Before the traffic reaches the resources in that subnet, the associated Network ACL checks its rules. Only traffic that matches the configured rules is allowed, while all other traffic is blocked. Similarly, all outgoing traffic from the subnet is also checked against the outbound rules.



5.1 Network ACL Basics

A **Network Access Control List (Network ACL or NACL)** provides an additional layer of security by controlling traffic at the subnet level. Every subnet in a VPC must be associated with a Network ACL. It evaluates both incoming and outgoing traffic based on the rules defined by the user.

Network ACL Associations:

Every subnet in a VPC is associated with a Network ACL.

- Every VPC has a default Network ACL.
- If a subnet is not associated with a custom Network ACL, it automatically uses the default

Network ACL.

- You can create custom Network ACLs to allow or deny specific inbound and outbound traffic.
- A single Network ACL can be associated with multiple subnets.
- However, one subnet can be associated with only one Network ACL at a time.
- When a new Network ACL is associated with a subnet, the previous association is automatically removed.

Network ACL Rules:

A Network ACL uses **inbound** and **outbound** rules to control network traffic.

Each rule contains:

- Rule number
- Traffic type (Inbound or Outbound)
- Protocol (TCP, UDP, ICMP, etc.)
- Port number or port range
- Source or destination
- Action (Allow or Deny)

Important points

- Rule numbers range from 1 to 32766.
- Rules are evaluated in ascending order (lowest rule number first).
- Once a matching rule is found, AWS stops checking the remaining rules.
- It is recommended to number rules in increments (such as 10, 20, 30 or 100, 200, 300) so that new rules can be added later.

Network ACL rules are checked whenever traffic enters or leaves a subnet.

Stateless Nature of Network ACLs:

Network ACLs are stateless, which means they do not remember previous network connections.

If inbound traffic is allowed, the corresponding outbound response is not automatically allowed.

A separate outbound rule must be created to allow the response traffic.

Example

Suppose a Network ACL allows HTTP requests (Port 80) from the internet.

- The incoming HTTP request is allowed.

R.M.K GROUP OF INSTITUTIONS

- The response from the EC2 instance will be blocked unless an outbound rule also allows the response traffic.

This is different from **Security Groups**, which are **stateful** and automatically allow response traffic.

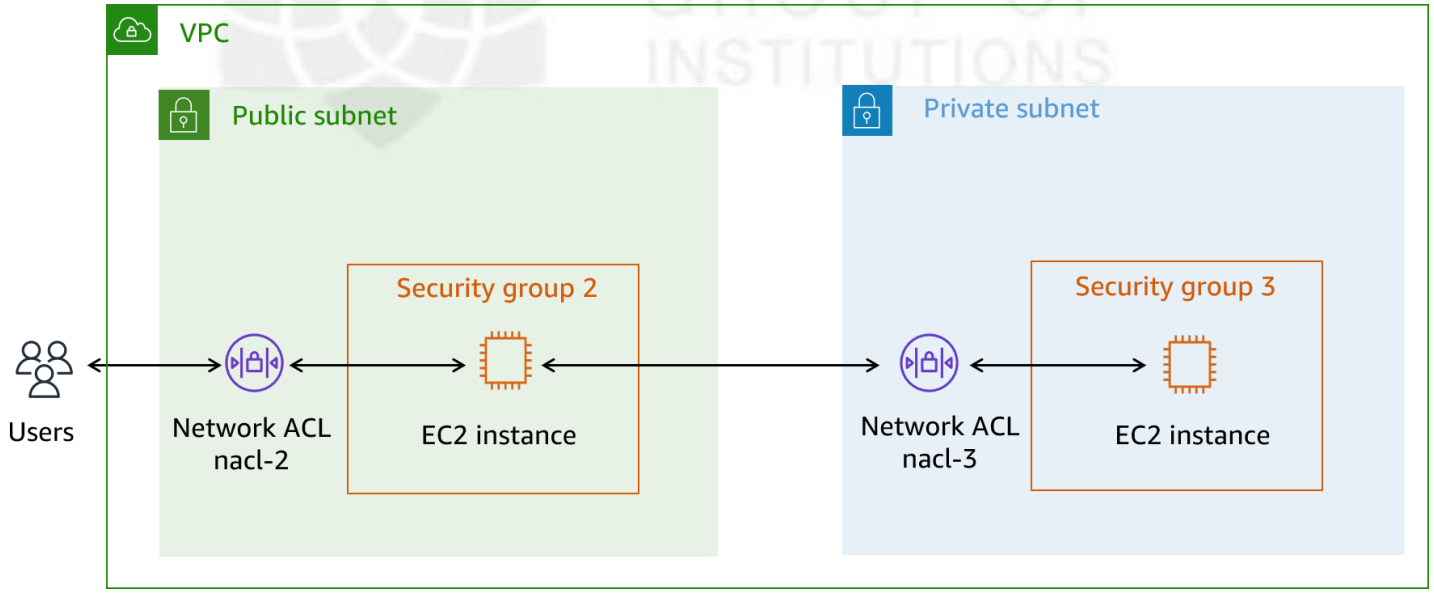
Best Practices:

To improve network security, follow these best practices:

- Use custom Network ACLs instead of relying only on the default Network ACL.
- Create separate inbound and outbound rules based on application requirements.
- Number rules with gaps (10, 20, 30...) to simplify future modifications.
- Use Network ACLs together with Security Groups for multiple layers of protection.
- Periodically review and remove unused or unnecessary rules.

Security Perspective

Network ACLs provide subnet-level security by allowing or denying network traffic before it reaches the resources inside the subnet. When used together with Security Groups, they create a defense-in-depth security model that strengthens the overall security of an AWS Virtual Private Cloud (VPC).



Above diagram shows how network ACLs work. A VPC contains a public subnet and a private subnet. Each subnet contains an EC2 instance. A network ACL in each subnet controls traffic to

and from the instances.

6. LOAD BALANCERS

A Load Balancer is a service that distributes incoming network or application traffic across multiple servers (targets) such as Amazon EC2 instances, containers, or IP addresses. AWS provides Elastic Load Balancing (ELB) to automatically distribute traffic, improve application availability, and ensure that no single server becomes overloaded.

Instead of sending all client requests to one server, a load balancer shares the workload among multiple healthy servers. This improves performance, scalability, fault tolerance, and security. If one server fails, the load balancer automatically redirects traffic to healthy servers, ensuring uninterrupted service.

From a cloud security perspective, load balancers provide a single entry point for client requests, support encrypted communication using SSL/TLS, and help protect backend servers by placing them in private subnets.

6.1 Elastic Load Balancing (ELB)

Elastic Load Balancing (ELB) is a fully managed AWS service that automatically distributes incoming application traffic across multiple registered targets in one or more Availability Zones (AZs). ELB continuously monitors the health of the registered targets and forwards requests only to healthy resources.

As application traffic increases or decreases, ELB automatically scales without requiring manual intervention. This ensures that applications remain highly available even during sudden traffic spikes.

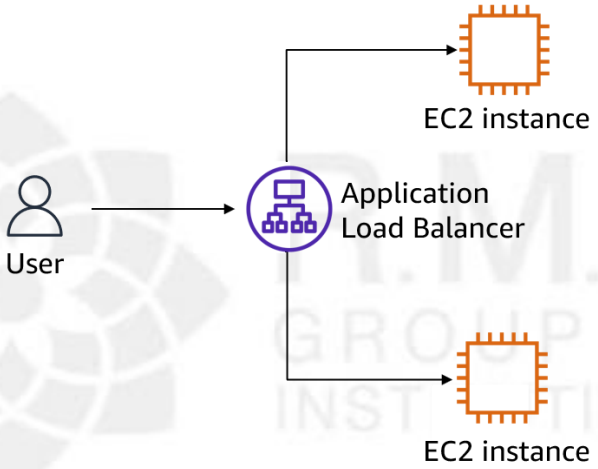
Features of Elastic Load Balancing

- Automatically distributes incoming traffic across multiple servers.
- Supports deployment across multiple Availability Zones.
- Continuously monitors the health of registered targets.
- Sends traffic only to healthy instances.
- Automatically scales based on incoming traffic.
- Integrates with services such as:
    - Amazon EC2 Auto Scaling

- Amazon ECS
- AWS CloudFormation
- AWS Certificate Manager (ACM)

Benefits of ELB

- Improves application availability.
- Provides fault tolerance.
- Prevents server overload.
- Supports automatic scaling.
- Reduces application downtime.
- Simplifies infrastructure management.



Types of Elastic Load Balancers

AWS provides three main types of load balancers.

1. Application Load Balancer (ALB)

The Application Load Balancer works at the Application Layer (Layer 7) of the OSI model. It routes HTTP and HTTPS requests based on the request content.

It can route requests based on:

- URL path
- Host name
- HTTP headers
- Query parameters

ALB is best suited for:

- Web applications
- REST APIs
- Microservices
- Container-based applications

It also supports HTTPS communication using SSL/TLS certificates managed by AWS Certificate Manager (ACM).

2. Network Load Balancer (NLB)

The Network Load Balancer operates at the Transport Layer (Layer 4).

It routes traffic based on:

- TCP
- UDP
- TLS protocols

NLB is designed for:

- High-performance applications
- Millions of requests per second
- Ultra-low latency applications
- Gaming and real-time communication systems

It supports static IP addresses and handles sudden increases in network traffic efficiently.

3. Classic Load Balancer (CLB)

The Classic Load Balancer is the older generation of AWS load balancers.

It supports:

- HTTP
- HTTPS
- TCP
- SSL

It performs basic load balancing for applications running in EC2-Classic environments. For new applications, AWS recommends using Application Load Balancer or Network Load Balancer instead.

6.2 How Elastic Load Balancer Works:

The working of an Elastic Load Balancer is simple and automatic.

Step 1 – Client Request

A user sends a request to the application's domain name.

Step 2 – DNS Resolution

Amazon DNS resolves the domain name and directs the request to the Elastic Load Balancer.

Step 3 – Listener Receives the Request

The load balancer receives the request through a Listener.

A Listener is a process that waits for client requests on a specific:

- Protocol (HTTP, HTTPS, TCP, TLS)
- Port number (80, 443, etc.)

Step 4 – Health Check

Before forwarding the request, ELB checks whether the registered targets are healthy.

If a server is unhealthy:

- It stops sending requests to that server.
- It automatically redirects traffic to healthy servers.

When the unhealthy server recovers, ELB starts routing traffic to it again.

Step 5 – Request Routing

The load balancer selects a healthy target and forwards the request using the target's private IP address.

Step 6 – Response

The target processes the request and sends the response back to the client through the load balancer.

6.3 Data Protection in Elastic Load Balancing

Elastic Load Balancing plays an important role in securing application traffic.

Single Point of Contact

The load balancer acts as the single entry point for client requests.

Instead of exposing multiple servers directly to the internet:

- Clients communicate only with the load balancer.
- Backend servers remain protected.

This improves both security and availability.

R.M.K GROUP OF INSTITUTIONS

Encryption in Transit

ELB supports secure communication using HTTPS and TLS.

The load balancer can perform SSL/TLS termination, which means:

- Incoming encrypted traffic is decrypted at the load balancer.
- Requests are forwarded to backend servers.
- Backend servers do not need to manage SSL certificates.

AWS Certificate Manager (ACM) can be used to create and manage SSL/TLS certificates.

Benefits

- Secure communication
- Reduced workload on EC2 instances
- Simplified certificate management

Encryption at Rest

Elastic Load Balancing stores access logs in Amazon S3.

If Server-Side Encryption (SSE-S3) is enabled:

- Access logs are automatically encrypted before storage.
- AWS automatically decrypts them when accessed.
- Encryption keys are regularly rotated for better security.

Security Best Practices

To secure Elastic Load Balancing:

- Enable HTTPS or TLS listeners.
- Use AWS Certificate Manager (ACM) for SSL certificates.
- Enable Multi-Factor Authentication (MFA) for AWS accounts.
- Use IAM roles with least privilege.
- Enable AWS CloudTrail for auditing.
- Protect web applications using AWS WAF.
- Configure Security Groups to allow traffic only from trusted sources.
- Allow EC2 instances to accept traffic only from the load balancer.

6.4 Load Balancers in Action

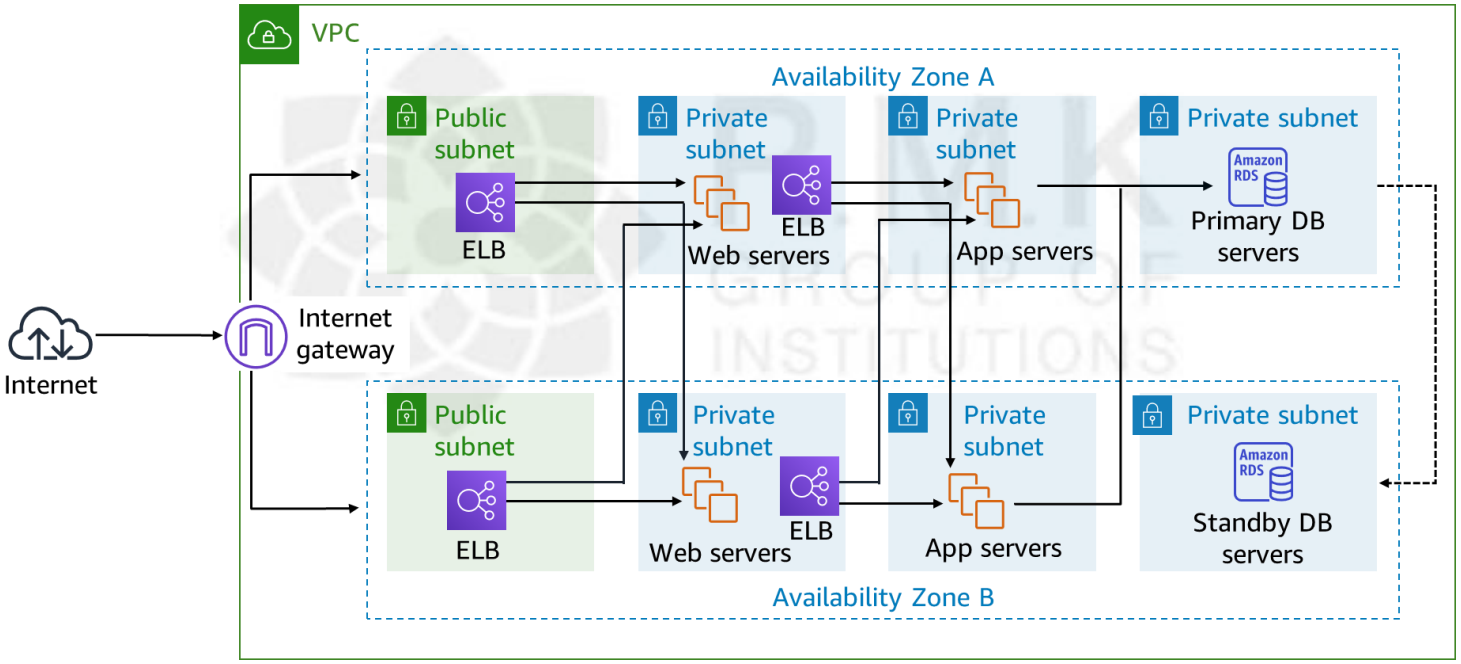
R.M.K GROUP OF INSTITUTIONS

A typical AWS application is deployed across multiple Availability Zones to improve reliability.

The architecture works as follows:

1. Internet users send requests to the application.
2. The requests reach the Internet Gateway.
3. An Application Load Balancer in the public subnet receives the requests.
4. The load balancer distributes the traffic among Web Servers located in private subnets.
5. Web servers forward requests to Application Servers in another private subnet.
6. Application servers communicate with the Primary Database.
7. A Standby Database in another Availability Zone continuously replicates data for disaster recovery.

If one Availability Zone fails, the load balancer automatically routes traffic to healthy servers in the other Availability Zone, ensuring uninterrupted application availability.



6.5 Security Perspective

Elastic Load Balancing is an important security component in AWS because it:

- Hides backend servers from direct internet access.
- Supports encrypted communication using HTTPS and TLS.
- Routes traffic only to healthy servers.

R.M.K GROUP OF INSTITUTIONS

- Improves application availability and fault tolerance.
- Supports multi-tier secure architectures.
- Integrates with AWS WAF, IAM, ACM, CloudTrail, and Auto Scaling for enhanced cloud security.

By distributing traffic efficiently and providing secure communication, Elastic Load Balancing helps build highly available, scalable, and secure cloud applications.

7. PROTECTING COMPUTE RESOURCES

Compute resources, such as Amazon EC2 instances, host applications and process sensitive data in the cloud. Protecting these resources is essential to prevent unauthorized access, detect vulnerabilities, and maintain the security and availability of applications. AWS provides services such as **Amazon Inspector** and **AWS Systems Manager** to continuously monitor, assess, and secure compute resources.

7.1 Amazon Inspector

Amazon Inspector is an automated security assessment service that helps identify security vulnerabilities and configuration issues in AWS workloads. It continuously scans Amazon EC2 instances and applications to detect vulnerabilities, unintended network exposure, and deviations from AWS security best practices.

Amazon Inspector performs security assessments both before applications are deployed **and** while they are running in production**.** This helps organizations identify and fix security issues at an early stage, reducing the risk of cyberattacks and improving overall system security.

After each assessment, Amazon Inspector generates a detailed report containing the identified security findings. The findings are prioritized based on their severity, enabling administrators to focus first on the most critical vulnerabilities.

Features of Amazon Inspector

- Performs automated security assessments of EC2 instances and applications.
- Detects software vulnerabilities and configuration issues.

- Identifies unintended network accessibility.
- Validates compliance with AWS security best practices.
- Generates detailed assessment reports with prioritized findings.
- Continuously monitors workloads for new vulnerabilities.

7.2 Security Benefits of Amazon Inspector

Amazon Inspector helps organizations improve the security of their cloud infrastructure by continuously identifying and reporting security risks.

1. Automated Security Response

Amazon Inspector integrates with Amazon EventBridge to automate responses to security findings. For example, when a critical vulnerability is detected, an automated workflow can notify administrators or trigger remediation actions.

2. Continuous Monitoring

Amazon Inspector regularly scans EC2 instances and applications for newly discovered vulnerabilities and security misconfigurations. Continuous monitoring ensures that security risks are detected even after applications are deployed.

3. AWS Security Expertise

Amazon Inspector uses AWS-developed security rules and vulnerability databases that are regularly updated. This enables organizations to benefit from AWS security best practices without manually maintaining security rules.

4. Integration with DevOps

Amazon Inspector supports integration with DevOps workflows through APIs and automation tools. Security assessments can become part of the software development lifecycle, allowing vulnerabilities to be detected before applications are released into production.

Benefits of Amazon Inspector

- Automates vulnerability assessments.

- Detects security issues early.
- Supports continuous security monitoring.
- Helps maintain compliance with security standards.
- Integrates easily with DevOps pipelines.
- Reduces the risk of security breaches.

7.3 AWS Systems Manager

AWS Systems Manager is a management service that provides visibility and control over AWS resources. It helps administrators monitor, configure, and manage EC2 instances from a single interface without requiring direct access to each server.

Amazon Inspector uses the **AWS Systems Manager Agent (SSM Agent)** installed on EC2 instances to collect information such as software inventory, operating system details, installed applications, and system configurations. This information is analyzed by Amazon Inspector to identify vulnerabilities and assess the security of workloads.

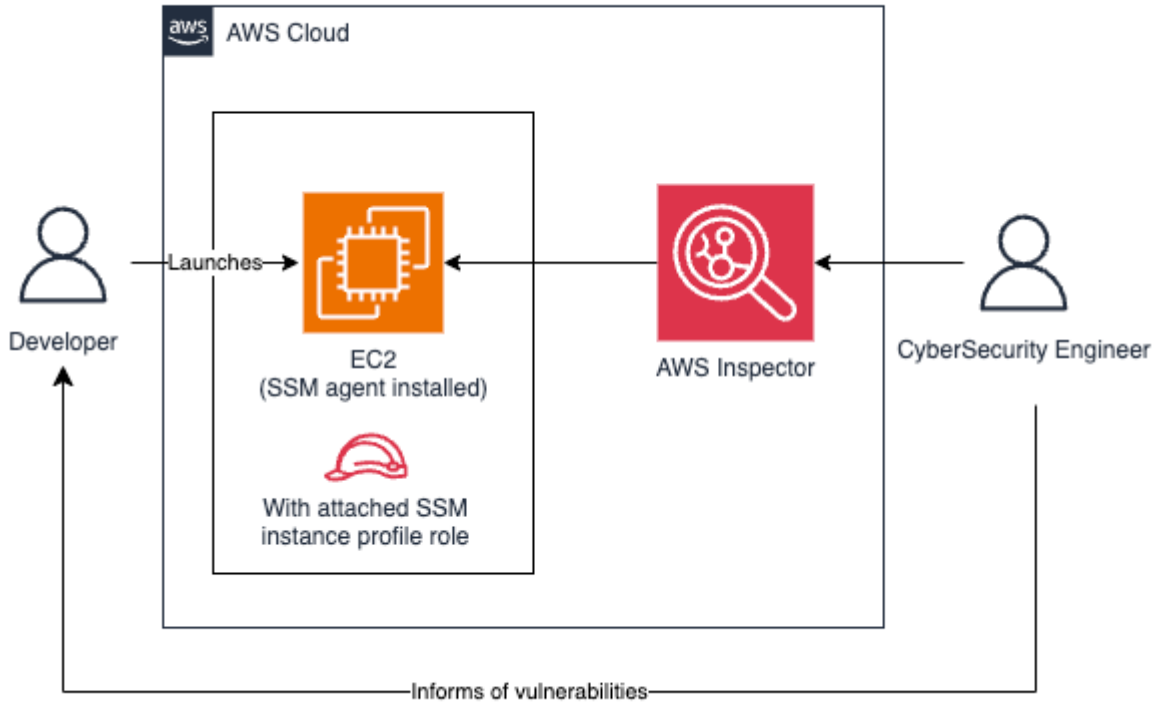
In addition to supporting Amazon Inspector, AWS Systems Manager simplifies day-to-day system administration by automating common maintenance tasks and ensuring that systems remain secure and compliant.

Features of AWS Systems Manager

- Collects software inventory from EC2 instances.
- Monitors system configurations.
- Automates operating system patch management.
- Updates antivirus definitions.
- Configures operating systems and applications at scale.
- Maintains compliance with organizational security policies.
- Provides centralized management of AWS infrastructure.

Benefits of AWS Systems Manager

- Simplifies infrastructure management.
- Improves visibility into compute resources.
- Automates routine administrative tasks.
- Helps maintain secure and compliant systems.
- Reduces manual effort through centralized management.
- Supports Amazon Inspector by providing system inventory and configuration data.



7.4 Security Perspective

Protecting compute resources is a key aspect of cloud security. **Amazon Inspector** continuously identifies vulnerabilities and security risks, while **AWS Systems Manager** collects system information and automates management tasks. Together, these services help organizations maintain secure, compliant, and well-managed compute resources by enabling continuous monitoring, automated security assessments, and timely remediation of vulnerabilities.

10. ASSIGNMENT

Assignment 1: Three-Tier Web Application Architecture Analysis

Difficulty Level: Beginner

Topic: Structure of a Three-Tier Web Application **(CO2, K2)**

Task: Analyze the architecture of a three-tier web application.

Instructions:

1. Study the presentation, application, and database tiers.
2. Draw a three-tier architecture diagram for an e-commerce application.
3. Explain the role of each tier.
4. Identify potential security threats associated with each tier.
5. Document your findings with diagrams and explanations.

Expected Output: A report containing the architecture diagram and security analysis.

Assignment 2: VPC Network Design

Difficulty Level: Intermediate

Topic: Virtual Private Cloud (VPC) **(CO2, K3)**

Task: Design a Virtual Private Cloud for a medium-sized organization.

Instructions:

1. Select an appropriate CIDR block.
2. Create a VPC layout showing public and private subnets.
3. Include an Internet Gateway and route tables.
4. Explain the purpose of each component.
5. Justify the network design decisions.

Expected Output: A VPC design document with diagrams and explanations.

Assignment 3: Public and Private Subnet Planning

Difficulty Level: Intermediate

Topic: Public and Private Subnets **(CO2, K3)**

Task: Plan subnet allocation for a cloud-hosted application.

Instructions:

1. Design a network with at least two public and two private subnets.
2. Assign application components to suitable subnets.
3. Explain how communication occurs between subnets.
4. Identify security considerations for each subnet.
5. Prepare a network diagram.

Expected Output: A subnet planning report with architecture diagrams.

Assignment 4: Security Groups and Network ACL Analysis

Difficulty Level: Advanced

Topic: Security Groups and Network ACLs **(CO2, K4)**

Task: Analyze traffic control mechanisms for a cloud environment.

Instructions:

1. Consider a web application hosted in a VPC.
2. Define inbound and outbound rules for Security Groups.
3. Define corresponding Network ACL rules.
4. Compare Security Groups and NACLs.
5. Recommend the most suitable security controls for different scenarios.

Expected Output: A comparative report with rule tables and recommendations.

R.M.K GROUP OF INSTITUTIONS

Assignment 5: Infrastructure Security Strategy

Difficulty Level: Expert

Topic: Load Balancers and Protecting Compute Resources **(CO2, K5)**

Task: Develop a security strategy for a cloud infrastructure.

Instructions:

1. Identify threats affecting compute resources.
2. Recommend protection mechanisms.
3. Explain how load balancers improve availability and security.
4. Propose security controls for web, application, and database tiers.
5. Prepare an infrastructure security plan.

Expected Output: A comprehensive infrastructure security strategy document

---

R.M.K GROUP OF INSTITUTIONS

11. PART A QUESTIONS AND ANSWERS

1.	**What is a three-tier web application?** A three-tier web application is a software architecture that separates an application into three layers: Presentation, Application (Business Logic), and Data Storage. This separation improves scalability, security, maintainability, and application performance.	K1
2.	**Name the three layers of a three-tier web application.** The three layers are the Presentation Layer, Application (Business Logic) Layer, and Data Storage Layer. Each layer performs a specific function and communicates only with the adjacent layer, improving modularity and security.	K1
3.	**What is the role of the Presentation Layer?** The Presentation Layer provides the user interface through web browsers or mobile applications. It accepts user requests, forwards them to the application layer, and displays the processed results to the user.	K2
4.	**What is the function of the Application Layer?** The Application Layer contains the business logic of the application. It validates user requests, performs authentication and authorization, processes transactions, and communicates with the database to retrieve or update data.	K2
5.	**Why is the Data Storage Layer placed in a private subnet?** The Data Storage Layer contains sensitive organizational data such as customer and financial records. Placing it in a private subnet prevents direct internet access, thereby improving security and reducing the attack surface.	K2
6.	**Define Amazon Virtual Private Cloud (Amazon VPC).** Amazon VPC is a service that allows users to create a logically isolated virtual network within the AWS Cloud. It enables secure deployment of AWS resources with complete control over IP addressing, routing, and network security.	K1
7.	**Mention any two features of Amazon VPC.** Amazon VPC provides logical isolation from other AWS networks and allows users to define custom IP address ranges using CIDR notation. It also supports subnets, route	K1

R.M.K GROUP OF INSTITUTIONS

	tables, Internet Gateways, and multiple security mechanisms.	
8.	**What is a subnet?** A subnet is a logical subdivision of a VPC that contains a specific range of IP addresses. Each subnet belongs to a single Availability Zone and helps organize resources based on functionality and security requirements.	K1
9.	**Differentiate between a public subnet and a private subnet.** A public subnet has a route to an Internet Gateway, allowing resources with public IP addresses to communicate with the internet. A private subnet has no direct internet access and is mainly used for application servers and databases.	K2
10.	**What is an Internet Gateway (IGW)?** An Internet Gateway is a VPC component that enables communication between AWS resources and the internet. It supports both IPv4 and IPv6 traffic and allows instances with public IP addresses to send and receive internet traffic.	K1
11.	**What is a NAT Gateway?** A NAT (Network Address Translation) Gateway is an AWS-managed service that allows instances in private subnets to access the internet without allowing inbound internet connections. It helps private resources download updates while remaining protected from external access.	K1
12.	**Why is a NAT Gateway deployed in a public subnet?** A NAT Gateway must be placed in a public subnet because it requires connectivity to the Internet Gateway. It translates private IP addresses into a public Elastic IP address, enabling outbound internet communication for private subnet instances.	K2
13.	**What is CIDR notation in AWS?** CIDR (Classless Inter-Domain Routing) is used to define the IP address range of a VPC or subnet. It helps allocate IP addresses efficiently and supports proper network planning and segmentation.	K1
14.	**Q. How many IP addresses are reserved by AWS in each subnet?A:** AWS reserves **five IP addresses** in every subnet for internal networking functions, including the network address, router, DNS server, future use, and broadcast	K1

R.M.K GROUP OF INSTITUTIONS

	address. These reserved addresses cannot be assigned to AWS resources.	
15.	**Differentiate between a Public IP Address and an Elastic IP Address.** A Public IP address is dynamically assigned and changes when an EC2 instance is stopped and restarted. An Elastic IP address is a static public IPv4 address that remains associated with an AWS account until it is explicitly released.	K2
16.	**What is an Elastic Network Interface (ENI)?** An Elastic Network Interface (ENI) is a virtual network adapter attached to an EC2 instance. It stores networking information such as private IP addresses, Elastic IP addresses, MAC address, and associated Security Groups.	K1
17.	**What is the purpose of a Route Table?** A Route Table contains routing rules that determine how network traffic flows between subnets, gateways, and external networks. Every subnet in a VPC must be associated with a route table for proper traffic routing.	K1
18.	**Define a Security Group in AWS.** A Security Group is a virtual firewall that controls inbound and outbound traffic for AWS resources such as EC2 instances. It provides instance-level security by allowing only authorized network traffic.	K1
19.	**Why are Security Groups called stateful firewalls?** Security Groups are stateful because they automatically allow return traffic for an established connection. If an inbound request is permitted, the response is automatically allowed without requiring an additional outbound rule.	K2
20.	**What are the default inbound and outbound rules of a Security Group?** By default, a Security Group denies all inbound traffic from external sources but allows all outbound traffic. Administrators can modify these rules based on application security requirements.	K2
21.	**What is a Network Access Control List (Network ACL)?** A Network ACL is a subnet-level firewall that controls inbound and outbound traffic entering or leaving a subnet. It supports both allow and deny rules, providing an additional layer of network security.	K1
22.	**Differentiate between Security Groups and Network ACLs.**	K2

R.M.K GROUP OF INSTITUTIONS

	Security Groups operate at the instance level and are stateful, automatically allowing response traffic. Network ACLs operate at the subnet level, are stateless, and require separate inbound and outbound rules for return traffic.	
23.	**What is a Load Balancer?** A Load Balancer distributes incoming client requests across multiple servers or instances. This improves application availability, fault tolerance, scalability, and ensures that no single server becomes overloaded.	K1
24.	**What is Elastic Load Balancing (ELB)?** Elastic Load Balancing (ELB) is a fully managed AWS service that automatically distributes incoming application traffic across multiple healthy targets in one or more Availability Zones. It improves application performance and availability.	K1
25.	**Name the three types of Elastic Load Balancers available in AWS.** AWS provides three types of Elastic Load Balancers: Application Load Balancer (ALB), Network Load Balancer (NLB), and Classic Load Balancer (CLB). Each is designed for different networking and application requirements.	K1
26.	**What is the primary function of an Application Load Balancer (ALB)?** An Application Load Balancer operates at Layer 7 of the OSI model and routes HTTP/HTTPS requests based on URL paths, host names, headers, and query parameters. It is commonly used for web applications and REST APIs.	K2
27.	**What is Amazon Inspector?** Amazon Inspector is an automated security assessment service that continuously scans AWS workloads for vulnerabilities, configuration issues, and unintended network exposure. It helps improve the security of EC2 instances and applications.	K1
28.	**Mention any two benefits of Amazon Inspector.** Amazon Inspector automates vulnerability assessments and continuously monitors workloads for new security risks. It also generates prioritized security reports, enabling administrators to address critical vulnerabilities quickly.	K2
29.	**What is AWS Systems Manager?** AWS Systems Manager is a management service that provides centralized visibility	K1

R.M.K GROUP OF INSTITUTIONS

	and control over AWS resources. It automates administrative tasks such as patch management, software inventory collection, and system configuration.	
30.	**How do Amazon Inspector and AWS Systems Manager work together?** AWS Systems Manager collects software inventory and configuration data from EC2 instances using the SSM Agent. Amazon Inspector uses this information to identify vulnerabilities, assess security risks, and recommend remediation actions.	K2

12. PART B QUESTIONS

1.	Design a secure three-tier web application for an online shopping system. Explain the functions of each layer and discuss how the architecture improves security, scalability, and availability with a neat diagram.	K5
2.	Analyze the role of Amazon VPC and subnets in building a secure cloud network. Explain the differences between public and private subnets with a suitable architecture.	K4
3.	Explain how Internet Gateway, NAT Gateway, and route tables work together to provide secure internet connectivity in AWS. Illustrate the traffic flow with a neat diagram.	K3
4.	Evaluate the importance of IP addressing, CIDR blocks, Elastic IP addresses, and Elastic Network Interfaces (ENI) in AWS networking. Explain how they support efficient and secure network management.	K5
5.	Analyze the working of Security Groups in AWS. Explain their features, rules, stateful nature, and best practices for protecting EC2 instances.	K4
6.	Analyze the working of Network Access Control Lists (Network ACLs). Explain their rule processing, stateless nature, and how they improve subnet-level security.	K4
7.	Design a secure and highly available application architecture using Elastic Load Balancing (ELB). Explain the types of load balancers and their role in improving application performance and security.	K5
8.	Apply the concepts of Amazon Inspector to improve the security of EC2 instances. Explain its features, assessment process, and security benefits with an example.	K3
9.	Explain how AWS Systems Manager helps administrators manage and secure compute resources. Discuss its features, benefits, and role in supporting Amazon Inspector.	K3
10.	Evaluate how the AWS services covered in this unit can be combined to build a secure cloud infrastructure. Justify how they support confidentiality, integrity, availability, and defense-in-depth.	K5

R.M.K GROUP OF INSTITUTIONS

13. ONLINE CERTIFICATIONS

1. **AWS Certified Cloud Practitioner**

   AWS Certified Cloud Practitioner Certification | AWS Certification | AWS (amazon.com)

2. **AWS Certified Solutions Architect – Associate**

   https://aws.amazon.com/certification/certified-solutions-architect-associate/

3. **AWS Certified Security – Specialty**

   https://aws.amazon.com/certification/certified-security-specialty/

R.M.K GROUP OF INSTITUTIONS

14. REAL TIME APPLICATIONS

Secure E-Commerce Web Application (Three-Tier Architecture)

A secure e-commerce application, such as an online shopping platform (e.g., Amazon, Flipkart, or Myntra), is a classic example of a **three-tier architecture** deployed on AWS. It separates the application into three layers—presentation, application, and database—to improve security, scalability, and availability**.**

How It Works

1. **Customers access the website**
    - Users browse the online shopping website using a web browser or mobile app.
    - Requests enter AWS through the **Internet Gateway**.
2. **Application Load Balancer (ALB)**
    - The ALB receives incoming requests and distributes them across multiple web servers.
    - This prevents a single server from becoming overloaded and improves availability.
3. **Web Tier (Public Subnet)**
    - Web servers (Amazon EC2) display product catalogs, login pages, and shopping carts.
    - Only ports **80 (HTTP)** and **443 (HTTPS)** are open to the internet.
4. **Application Tier (Private Subnet)**
    - Application servers process business logic such as:
        - User authentication
        - Product search
        - Order processing
        - Payment validation
    - These servers cannot be accessed directly from the internet.
5. **Database Tier (Private Subnet)**
    - Amazon RDS stores customer accounts, product information, inventory, and order details.
    - Only application servers are permitted to communicate with the database.

AWS Services Used

- Amazon VPC – Creates an isolated virtual network.
- Public and Private Subnets – Separate internet-facing and internal resources.

R.M.K GROUP OF INSTITUTIONS

- Internet Gateway – Enables internet connectivity for the web tier.
- Application Load Balancer (ALB) – Distributes incoming traffic across web servers.
- Amazon EC2 – Hosts web and application servers.
- Amazon RDS – Stores relational data securely.
- Security Groups – Act as virtual firewalls for EC2 instances.
- Network ACLs – Provide subnet-level traffic filtering.
- Auto Scaling – Automatically adds or removes EC2 instances based on demand.

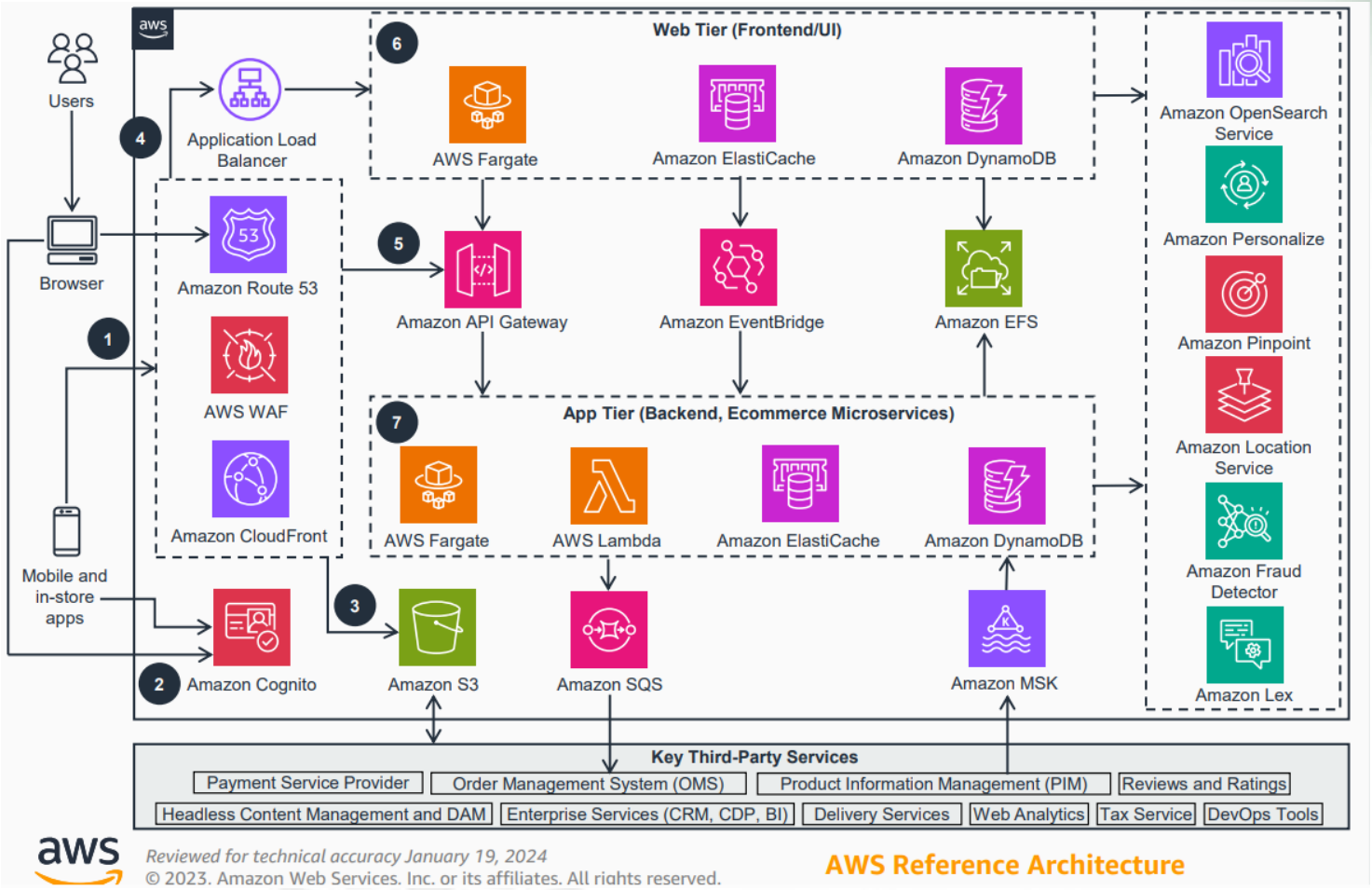
Security Measures

- Web servers are placed in public subnets, while application and database servers remain in private subnets.
- Security Groups allow only necessary traffic between tiers.
- Network ACLs provide an additional layer of subnet-level security.
- The database is never directly accessible from the internet.
- All communication uses HTTPS to encrypt data in transit.
- Auto Scaling and the Load Balancer improve availability during traffic spikes or server failures.

Benefits

- High Security: Sensitive application and database servers are isolated from the public internet.
- Scalability: Auto Scaling and Load Balancer handle increasing customer traffic.
- High Availability: Multiple EC2 instances ensure continuous service even if one fails.
- Performance: Load balancing distributes requests efficiently.
- Cost Optimization: Resources scale automatically based on demand.

R.M.K GROUP OF INSTITUTIONS



https://docs.aws.amazon.com/solutions/web-store-on-aws/

15. SELF-LEARNING / ENRICHMENT TOPICS

1. AWS Transit Gateway:
   Connects multiple VPCs and on-premises networks through a centralized networking hub.
2. AWS PrivateLink and VPC Endpoints:
   Enable secure private access to AWS services without routing traffic over the public internet.
3. VPC Flow Logs:
   Capture and analyze network traffic information for monitoring and troubleshooting.
4. Traffic Mirroring:
   Replicates network traffic from EC2 instances for security analysis and packet inspection.
5. Hybrid Cloud Networking (Direct Connect & VPN):
   Establishes secure connectivity between on-premises infrastructure and AWS cloud environments.
6. Infrastructure as Code Security (CloudFormation/Terraform):
   Automates secure infrastructure provisioning and management using code-based templates.
7. Secure Bastion Hosts with AWS Systems Manager Session Manager:
   Provides secure remote access to EC2 instances without opening inbound SSH ports.
8. AI-Based Network Threat Detection:
   Uses artificial intelligence and machine learning to identify network anomalies and potential cyber threats in real time.

16. ASSESSMENT SCHEDULE

Tentative schedule for the Assessment During 2026-2027 Odd semester

S.NO	Name of the Assessment	Start Date	End Date	Portion
1	IAT 1	28.07.2026	04.08.2026	UNIT 1 & 2
2	IAT 2	31.08.2026	08.09.2026	UNIT 3 & 4
3	REVISION	-	-	UNIT 5, 1 & 2
4	MODEL	21.09.2026	28.09.2026	ALL 5 UNITS

17. PRESCRIBED TEXT BOOKS AND REFERENCES

TEXT BOOKS:

1. Tim Mather, Subra Kumaraswamy, Shahed Latif, "Cloud Security and Privacy, An Enterprise Perspective on Risks and Compliance", Oreilly Media 2009.
2. Vic (J.R.) Winkler, "Securing the Cloud, Cloud Computer Security Techniques and Tactics", Syngress, April 2011.

REFERENCES:

1. Rajkumar Buyya, James Broberg, Andrzej, "Cloud Computing: Principles and Paradigms", Wiley India Publications 2011.
2. Arshdeep Bahga and Vijay Madisetti, "Cloud Computing –A Hands on Approach", Universities Press (India) Pvt Ltd. 2014.

R.M.K GROUP OF INSTITUTIONS

18. MINI PROJECT

Mini-Project 1: Secure Three-Tier Application Blueprint (CO2, K3)

Objective:

Design a secure three-tier architecture for an online shopping application.

Tasks:

1. Identify web, application, and database tiers.
2. Create an architecture diagram.
3. Define communication between tiers.
4. Identify security measures for each layer.
5. Present the design.

Mini-Project 2: VPC Design for a Smart Hospital (CO2, K4)

Objective:

Design a cloud network infrastructure for a smart hospital.

Tasks:

1. Create a VPC architecture.
2. Design public and private subnets.
3. Define routing mechanisms.
4. Identify resources that should be isolated.
5. Prepare a network design report.

Mini-Project 3: Security Group and NACL Policy Design (CO2, K4)

Objective:

Develop access control policies for a cloud-based university portal.

Tasks:

1. Identify users and services.
2. Create Security Group rules.
3. Design Network ACL rules.

R.M.K GROUP OF INSTITUTIONS

4. Explain traffic filtering decisions.
5. Present the policy design.

Mini-Project 4: Load Balancer Selection Study (CO2, K4)

Objective:

Evaluate different load balancing approaches for cloud applications.

Tasks:

1. Study Application, Network, and Classic Load Balancers.
2. Compare their features.
3. Select suitable load balancers for different business scenarios.
4. Create a comparison matrix.
5. Present recommendations.

Mini-Project 5: Secure Infrastructure Design for a Startup (CO2, K5)

Objective:

Design a secure cloud infrastructure for a startup deploying a web application.

Tasks:

1. Create a three-tier architecture.
2. Design VPC, subnets, and routing.
3. Incorporate Security Groups and NACLs.
4. Include load balancing and compute protection measures.
5. Prepare architecture diagrams and a security plan.

19. AI APPLICATIONS

1. **AI-Based Cloud Infrastructure Protection**

   AI helps protect cloud infrastructure by continuously monitoring cloud resources such as virtual machines, networks, storage, and databases. It analyzes system activities to identify vulnerabilities, detect suspicious behavior, and recommend security improvements. AI can also automate responses to security incidents, reducing the time required to detect and mitigate threats.

2. **Machine Learning for Network Anomaly Detection**

   Machine Learning (ML) analyzes network traffic patterns to learn what is considered normal behavior. It can identify unusual activities such as unauthorized access attempts, Distributed Denial-of-Service (DDoS) attacks, malware communication, or abnormal data transfers. By detecting anomalies in real time, ML enables organizations to respond quickly to potential cyber threats.

3. **AI-Powered Firewall and VPC Security**

   AI enhances traditional firewalls by automatically analyzing network traffic and identifying malicious requests. It can dynamically update firewall rules, block suspicious IP addresses, and prevent unauthorized access to resources within a Virtual Private Cloud (VPC). AI also helps optimize Security Groups and Network ACL configurations to strengthen network security.

4. **AI in Cloud Workload Protection**

   AI continuously monitors cloud workloads such as EC2 instances, containers, and serverless applications to detect vulnerabilities, malware, and abnormal behavior. It identifies security risks, prioritizes critical threats, and recommends corrective actions. AI-based workload protection improves compliance, reduces manual monitoring, and ensures that cloud applications remain secure throughout their lifecycle.

R.M.K GROUP OF INSTITUTIONS

Thank you

Disclaimer:

This document is confidential and intended solely for the educational purpose of RMK Group of Educational Institutions. If you have received this document through email in error, please notify the system manager. This document contains proprietary information and is intended only to the respective group / learning community as intended. If you are not the addressee you should not disseminate, distribute or copy through e-mail. Please notify the sender immediately by e-mail if you have received this document by mistake and delete this document from your system. If you are not the intended recipient you are notified that disclosing, copying, distributing or taking any action in reliance on the contents of this information is strictly prohibited.